**ASSIGNMENT FINAL REPORT**

| | | | |
|---|---|---|---|
| **Qualification** | **Pearson BTEC Level 5 Higher National Diploma in Computing** | | |
| **Unit number and title** | **Unit 16: Computing Research Project (Pearson-set)** | | |
| **Submission date** | | **Date Received 1st submission** | |
| **Re-submission Date** | | **Date Received 2nd submission** | |
| **Student Name** | Pham The Dang | **Student ID** | BH01842 |
| **Class** | SE07204 | **Assessor name** | Dinh Van Dong |

### Plagiarism

Plagiarism is a particular form of cheating. Plagiarism must be avoided at all costs and students who break the rules, however innocently, may be penalised. It is your responsibility to ensure that you understand correct referencing practices. As a university level student, you are expected to use appropriate references throughout and keep carefully detailed notes of all your sources of materials for material you have used in your work, including any material downloaded from the Internet. Please consult the relevant unit lecturer or your course tutor if you need any further advice.

### Student Declaration

I certify that the assignment submission is entirely my own work and I fully understand the consequences of plagiarism. I declare that the work submitted for assessment has been carried out without assistance other than that which is acceptable according to the rules of the specification. I certify I have clearly referenced any sources and any artificial intelligence (AI) tools used in the work. I understand that making a false declaration is a form of malpractice.

| | |
|---|---|
| **Student's signature** | Dang |

**Grading grid**

| P1 | P2 | P3 | P4 | P5 | P6 | P7 | M1 | M2 | M3 | M4 | D1 | D2 | D3 |
|---|---|---|---|---|---|---|---|---|---|---|---|---|---|
| | | | | | | | | | | | | | |

| r Summative Feedback: | r Resubmission Feedback: |
|---|---|
| | |

| Grade: | Assessor Signature: | Date: |
|---|---|---|

**Internal Verifier's Comments:**

**Signature & Date:**

# Table of Contents


**I Introduction** ..... 6

**II Body** ..... 6

**1. Research Proposal: optimizing cybersecurity through zero trust architecture (P1)** ..... 6

1.1 Research purpose. ..... 6

1.2 Aims and objectives. ..... 7

1.3 Scope of the research. ..... 7

1.4 Literature review. ..... 7

**2. Literature review (P2)** ..... 10

2.1 Examine appropriate research methods and approaches to primary and secondary research. ..... 10

2.2 Analyse different research approaches and methodologies and make justifications for the choice of methods selected based on philosophical/theoretical frameworks. (M1) ..... 13

2.3 Critically evaluate research methodologies and processes in application to a computing research project to justify chosen research methods and analysis (D1) ..... 16

2.4 Conducting Secondary Research for the Computing Research Project (P3) ..... 18

2.5 Conclusion, propose an initial hypothesis after the literature review and need to confirm in your primary research. ..... 20

**3. Conduct Primary Research Using Appropriate Methods. (P3)** ..... 21

3.1 Research tools and approach. ..... 21

3.2 Primary research results: Expert Interview Analysis ..... 25

**4. Apply appropriate analytical tools, analyse research findings and data (P4)** ..... 30

4.1 Identify appropriate data analysis tools: ..... 30

4.2 Analyze the data collected from primary research ..... 31

**5. Discuss merits, limitations and pitfalls of approaches to data collection and analysis(M2)** ..... 37

5.1. Merits of Data Collection and Analysis Approaches ..... 38

5.2. Limitations of Data Collection and Analysis Approaches ..... 39

5.3. Pitfalls of Data Collection and Analysis Approaches ..... 40

**6. Communicate research outcomes in an appropriate manner for the intended audience(P5)** ..... 41

6.1 Communication for Technical Experts (Zero Trust Perspective) ..... 41

6.2 Communication for General Users ..... 42

6.3 Integrated Communication Strategy ..... 43

**7. Analyze the extent to which outcomes meet set research objectives and communicate judgements effectively for the intended audience (M3)** ..... 44

**8. Evaluate outcomes and make valid, justified recommendations (D2)** ..... 48

8.1. Critical Evaluation of Outcomes ..... 48

8.2. Valid, Justified Recommendations ..... 48

**9. Discuss the effectiveness of research methods applied, for meeting objectives of the computing research project. (P6)** ..... 49

9.1. Project's proposal, the research process (sequential example) how it helped you completed your research 49

9.2. Reflection on the Merits, Limitations, and Potential Pitfalls of Chosen Methods ..... 51

9.3. The Roles of Literature Review in the Project ..... 52

**10. Discuss alternative research methodologies and lessons learnt in view of the outcomes (P7)** ..... 53

10.1. Discussion on Alternative Research Methodologies ..... 53

10.2. Lessons Learnt from the Project ..... 56

10.3. Improvements and Future Research Directions ..... 57

**11. Analyze results in recommended actions for improvements and future research considerations(M4)** 58

11.1. Analytical overview of results ..... 58

11.2. Recommendations for improving future research ..... 61

11.3. Practical applications and future integration ..... 62

**12. Demonstrate reflection and engagement in the resource process leading to recommended actions for future improvement (D3)** ..... 64

12.1. Reflection on Project Planning and Resource Management ..... 64

12.2. Strategic sampling, data selection, and reflective lessons ..... 64

12.3. Recommended actions for future improvements ..... 65

**III Conclusion** ..... 65

**IV Reference** ..... 66

# I Introduction

The rapid growth of remote work, cloud computing, and distributed access has made traditional perimeter-based security models increasingly ineffective. In many organizations, internal systems still rely on implicit trust once users successfully log in, which creates serious risks such as credential theft, insider threats, and lateral movement attacks.

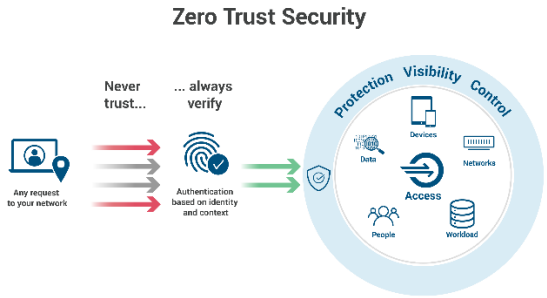
To address these challenges, Zero Trust Architecture (ZTA) introduces the principle of "Never Trust, Always Verify." Instead of assuming trust based on network location, every access request must be continuously authenticated, authorized, and validated based on user role, device status, and contextual information.

This project develops an internal company monitoring website based on the Zero Trust model. The system integrates Role-Based Access Control (RBAC), continuous authentication, and real-time activity monitoring to enhance enterprise security and prevent unauthorized access.

The platform is built using React, TypeScript, Node.js, Express, MongoDB, and TailwindCSS, demonstrating how Zero Trust principles can be practically implemented in a modern web-based enterprise environment.

# II Body

## 1. Research Proposal: optimizing cybersecurity through zero trust architecture (P1)




### 1.1 Research purpose.

The objective of this research is to explore how **Zero Trust Architecture (ZTA) can be implemented in a corporate internal web system to improve enterprise security in a decentralized working environment**. Traditional perimeter-based security models assume that users inside the network can be trusted. However, with the rise of remote work, cloud services, and mobile access, this assumption is no longer reliable.

Many current systems still rely on implicit trust after initial login, which creates serious risks when credentials are stolen or internal accounts are compromised. Once attackers gain access, they can move laterally across the network and reach sensitive data.

This research therefore investigates how Zero Trust principles—such as continuous authentication, Least Privilege access, Role-Based Access Control (RBAC), and real-time activity monitoring—can be integrated into a unified web platform. The goal is to eliminate default trust, restrict unnecessary access, and prevent internal and external security threats more effectively.

Ultimately, the study aims to design a proactive security approach that continuously verifies users and devices, providing stronger protection for modern organizations.

**1.2 Aims and objectives.**

- **Aim:** To quantitatively and qualitatively evaluate how Zero Trust enhances system resilience and to build a framework for implementing "Least Privilege" access.
- **Objectives:**
  - Comparative Analysis: Contrast the vulnerabilities of traditional models with the protection layers of Zero Trust.
  - Define Technical Pillars: Deep dive into MFA (Multi-Factor Authentication), Micro-segmentation (dividing the network into small, locked rooms), and IAM (Identity and Access Management).
  - Simulated Testing: Use attack scenarios like *Credential Stuffing* (using leaked passwords) to measure how well Zero Trust stops an intruder.
  - User Experience Optimization: Propose a strategy to tighten security without making the workflow slow or frustrating for employees.

**1.3 Scope of the research.**

- **What the Research WILL Do:**
  - Analyze the 5 pillars of the CISA Maturity Model: Identity, Device, Network, Application, and Data.
  - Focus on Just-In-Time (JIT) access: Giving a user permission *only* when they need it and revoking it immediately after.
  - Apply the NIST SP 800-207 standard (the global "gold standard" for Zero Trust).
- **What the Research WILL NOT Do:**
  - Develop new software (we will use and evaluate existing industry solutions).
  - Analyze "Legacy Systems" (very old computers/software) that cannot support modern security protocols like MFA.

**1.4 Literature review.**

**1. Article in Springer – Cybersecurity (2024)**

**Title:** *Dissecting Zero Trust: Research Landscape and Its Implementation in IoT*

**Authors:** Cheng Liu, Rui Tan, Yan Wu, Yan Feng, Zhikai Jin, Fan Zhang, Yi Liu, and Qin Liu

**Journal:**Cybersecurity
**Year:** 2024
**Link:** https://link.springer.com/article/10.1186/s42400-024-00212-0
**Analysis**
This article provides a comprehensive analysis of the Zero Trust (ZT) security model within the context of the Internet of Things (IoT). The authors examine the current research landscape, existing architectural models, and the major challenges associated with implementing Zero Trust in IoT environments.
Key contributions include:
- A systematic review of existing Zero Trust architectures.
- Evaluation of continuous authentication mechanisms.
- Identification of implementation challenges in IoT devices with:
    - Limited computational power
    - Restricted memory capacity
    - Energy constraints

The paper proposes a structured roadmap for deploying stricter security mechanisms in large-scale smart device ecosystems.
**Main contribution:** A holistic overview of Zero Trust integration strategies tailored to IoT networks.
**2. Article in JESSI (2023)**
**Title:** *Software Quality Analysis of Web-Based Information Systems Using the ISO/IEC 25010 Standard*
**Authors:** Aris Baharuddin et al.
**Journal:** Journal of Engineering Software and Systems Information
**Year:** 2023
**Link:** https://journal.unm.ac.id/index.php/JESSI/article/view/8272
**Analysis**
This study evaluates the quality of a web-based information system using the ISO/IEC 25010 international software quality standard.
The assessment focuses on the following quality characteristics:
- **Usability**
- **Performance Efficiency**
- **Reliability**
- **Maintainability**

The evaluated system typically represents an academic or organizational management platform.
**Main contribution:** The research identifies software weaknesses and provides structured recommendations to enhance user experience and system performance through standardized quality evaluation.
**3. Article in ScienceDirect – Computers & Security (2024)**

**Title:** *Zero Trust Architecture for Industrial Internet of Things: A Systematic Review*
**Authors:** Mohamed Amine Ferrag, Lei Shu, Xing Yang, et al.
**Journal:** Computers & Security
**Year:** 2024
**Link:** https://www.sciencedirect.com/science/article/pii/S016740482300322X
**Analysis**
This article presents a Systematic Literature Review (SLR) on the implementation of Zero Trust Architecture (ZTA) in Industrial Internet of Things (IIoT) environments.
The study:

- Classifies major cyber threats in smart factories, including:
  - Insider attacks
  - Ransomware
  - Attacks targeting Industrial Control Systems (ICS)
- Evaluates how Zero Trust mitigates lateral movement and enforces micro-segmentation.
- Explores integration with emerging technologies such as:
  - Blockchain
  - AI-based anomaly detection systems

**Main contribution:** A structured synthesis of Zero Trust applications in IIoT and identification of future research directions combining ZTA with advanced technologies.

**4. Article in MDPI Sensors (2025)**
**Title:** *A Systematic Literature Review on the Implementation and Challenges of Zero Trust Architecture Across Domains*
**Authors:** Sadaf Mushtaq, Muhammad Mohsin, and Muhammad Mujahid Mushtaq
**Journal:** Sensors
**Year:** 2025
**Link:** https://www.mdpi.com/1424-8220/25/19/6118
**Analysis**
This study conducts a systematic review of Zero Trust implementation across multiple sectors, including:

- Information Technology
- Healthcare
- Finance
- E-government

The research identifies both technical and organizational barriers in transitioning from traditional perimeter-based security models to Zero Trust architecture.
Technical challenges include:

- High deployment costs
- Integration issues with legacy systems

Organizational and psychological challenges include:

- Resistance to change

- Limited awareness of Zero Trust principles

**Main contribution:** A cross-domain evaluation of Zero Trust adoption barriers and strategic insights for facilitating organizational transformation.

**5. Article in MDPI Electronics (2024)**

**Title:** *Enhancing Zero Trust Models in the Financial Industry through Blockchain Integration: A Proposed Framework*

**Authors:** Clement Daah, Amna Qureshi, Irfan Awan, and Savas Konur

**Journal:** Electronics

**Year:** 2024

**Link:** https://www.mdpi.com/2079-9292/13/5/865

**Analysis**

This paper proposes a Zero Trust framework specifically designed for the financial industry by integrating Blockchain technology.

The framework:

- Applies the principle of "Never Trust, Always Verify."
- Leverages blockchain properties such as:
  - Immutability
  - Distributed validation
- Enhances:
  - Fraud detection
  - Insider threat prevention
  - Decentralized access control

**Main contribution:** A dual-layer security model combining Zero Trust and Blockchain to strengthen cybersecurity resilience in banking and financial systems.

## 2. Literature review (P2)

### 2.1 Examine appropriate research methods and approaches to primary and secondary research.

In computing research, particularly in cybersecurity and secure web architecture, selecting appropriate research methods is essential to ensure that findings are valid, ethical, and practically applicable. This research adopts a combination of primary and secondary research methods, integrating both quantitative and qualitative approaches to build a scientifically rigorous evaluation of the Zero Trust security model in web systems.

The study is grounded in a positivist research philosophy, which emphasizes objective measurement, empirical testing, and reproducibility. Since Zero Trust implementation involves measurable security controls, access policies, and system performance metrics, a positivist approach supports controlled experimentation and statistical evaluation. This philosophical stance justifies the use of experimental testing, log analysis, and performance benchmarking to assess how effectively Zero Trust reduces cyber risks while maintaining usability.

This subsection focuses on the primary research methods used in the project. Secondary research is discussed in the following section.

**a) Primary Research**

Primary research involves generating original data through experimentation and direct system observation. In this project, primary research is essential for designing, implementing, and evaluating a Zero Trust web architecture.

**Experimental System Development**

The core primary research activity involves building two web environments**:**

- A traditional security model (firewall + login-based trust)
- A Zero Trust model (continuous verification + least privilege access)

Both systems are deployed in a controlled environment using containerization and a three-tier architecture (frontend, backend, database).

**The Zero Trust model includes:**

- Identity-based access verification for every request
- Role-Based Access Control (RBAC)
- API-level permission enforcement
- Database micro-segmentation
- Continuous token validation

**Attack Simulation and Security Testing**

To evaluate effectiveness, simulated cyberattack scenarios are conducted, inspired by standards from OWASP.

Test scenarios include:

- Unauthorized access attempts to restricted endpoints
- Privilege escalation attempts
- SQL injection simulations
- Lateral movement attempts between backend and database

The goal is to measure whether Zero Trust policies successfully block unauthorized access even if part of the system is compromised.

**Target "Population" (System Data and Logs)**

Instead of human participants, the "population" in this research consists of:

- API request logs
- Authentication records
- Access control decisions
- Network traffic logs

All data is ethically generated within a controlled lab environment, ensuring no real user privacy is violated.

**Advantages of Primary Research**

- Direct Relevance: Security metrics are generated specifically to evaluate Zero Trust effectiveness.

- Control Over Environment: The researcher controls configuration, policies, and testing conditions.
- Up-to-date Implementation: The model reflects modern authentication standards (OAuth2, JWT, MFA).
- Cybersecurity Impact: Empirical results directly support the objective of reducing web-based attack risks.

Limitations

- Resource Requirements: Simulation and testing require computing infrastructure and technical setup.
- Scenario Dependency: Results depend on selected attack simulations.
- Generalization Challenges: Lab conditions may not perfectly represent large-scale enterprise systems.
- Complexity of Policy Tuning: Misconfiguration can affect performance or produce false positives.

Despite these limitations, experimental primary research is necessary to objectively measure Zero Trust's real-world effectiveness.

**b) Secondary Research**

Secondary research supports the theoretical and contextual foundation of the study. It includes reviewing academic literature, industry standards, and cybersecurity case studies related to Zero Trust. Sources include:

- Academic publications on Zero Trust Architecture and Least Privilege models
- Industry frameworks such as NIST Zero Trust guidelines
- Security vulnerability analysis from OWASP
- Real-world implementation case studies such as Google BeyondCorp by Google

Secondary research informs:

- Policy design decisions
- Authentication mechanisms
- Micro-segmentation strategies
- Risk-based access control principles

**Advantages**

- Strong Theoretical Foundation
- Benchmarking Capability against industry standards
- Time and Cost Efficiency
- Access to Established Security Frameworks

**Limitations**

- Some frameworks may not fully reflect emerging web threats.
- Industry reports may vary in technical depth.
- Published models may require adaptation for smaller-scale systems.

Ethically, this research relies only on publicly available standards and documented case studies, ensuring transparency and responsible use of information.

**c) Quantitative and Qualitative Approaches (Mixed Methods)**

This study combines quantitative technical evaluation with qualitative contextual analysis.

**Quantitative Methods**

Quantitative data is used to measure system performance and security effectiveness. Key evaluation metrics include:

- Unauthorized Request Block Rate
- False Positive Rate
- Authentication Latency (TTFB impact)
- Access Violation Detection Rate

These measurable indicators provide objective evidence of how Zero Trust improves security compared to traditional models.

**Qualitative Methods**

Qualitative analysis focuses on understanding broader cybersecurity implications, including:

- How Zero Trust changes DevSecOps practices
- The impact of continuous authentication on user experience
- Ethical implications of monitoring device posture and location
- Risk assessment of insider threats

Qualitative insights ensure that the model is not only technically effective but also practical and ethically responsible.

## 2.2 Analyse different research approaches and methodologies and make justifications for the choice of methods selected based on philosophical/theoretical frameworks. (M1)

Research in computing, particularly in cybersecurity architecture such as **Zero Trust**, requires an approach that supports both measurable technical evaluation and contextual understanding of modern cyber threats. Several research methodologies may be applied in this domain, including quantitative, qualitative, and mixed methods approaches.

For this project, a mixed methods approach has been selected because it best addresses the dual objectives of evaluating the technical effectiveness of the **Zero Trust model** while also understanding its practical, organizational, and ethical implications.

### a) Quantitative Research Approach

The quantitative approach in this study focuses on collecting and analyzing measurable numerical data to evaluate the technical performance of the Zero Trust-based internal web system. This method is used to examine security effectiveness and system efficiency through objective and statistically verifiable indicators.

In this project, quantitative methods are applied to:

- Process structured data from access logs, HTTP requests, and authentication records.
- Measure system performance before and after Zero Trust implementation.
- Analyze authentication latency, request verification time, and overall system throughput.
- Evaluate security metrics such as:
    - Unauthorized request block rate
    - False positive rate
    - Access violation detection rate
    - Time required to detect and block suspicious activities
- Test authentication mechanisms (e.g., JWT and Refresh Token) using load testing and penetration testing.
- Compare traditional perimeter-based architecture with Zero Trust architecture through controlled experiments.

Quantitative research is particularly suitable for assessing the technical dimension of Zero Trust, where objective measurement is essential to determine performance improvements and security enhancements. This approach aligns with the positivist philosophy, which assumes that system behavior, security vulnerabilities, and performance impacts can be measured and validated through empirical evidence.

However, quantitative data alone cannot fully capture human and organizational factors, such as user behavior, usability concerns, resistance to continuous monitoring, or social engineering risks. Since cybersecurity involves both technical systems and human interaction, relying solely on numerical indicators may provide an incomplete understanding of Zero Trust implementation.

**b) Qualitative Research Approach**

The qualitative approach in this study focuses on understanding the contextual and human aspects of implementing Zero Trust Architecture within a corporate internal web system. While quantitative data measures system performance, qualitative analysis helps explain how Zero Trust affects users, administrators, and organizational processes.

In this project, qualitative methods are used to:

- Examine how Zero Trust shifts the traditional security mindset from “trust after login” to “never trust, always verify.”

- Analyze real-world cybersecurity reports and case studies involving data breaches caused by excessive privileges or weak internal controls.
- Explore usability challenges, such as authentication fatigue resulting from multi-factor verification and continuous access validation.
- Assess ethical and privacy concerns related to device monitoring, behavioral tracking, and user activity logging within the internal system.

This approach is grounded in the interpretivist paradigm, which acknowledges that cybersecurity practices are influenced not only by technical mechanisms but also by human behavior, organizational culture, and contextual risk factors.

Qualitative analysis is particularly useful in explaining why access control failures occur and how Zero Trust principles can reduce insider threats, privilege escalation, and lateral movement within a company's internal network. However, qualitative findings are inherently contextual and cannot independently measure technical performance or security effectiveness. Therefore, they must be complemented by quantitative evaluation.

**c) Mixed Methods Approach**

Since this project evaluates both the technical performance of a Zero Trust-based internal web system and its organizational impact, a mixed methods approach is the most appropriate research strategy.

This methodology allows the study to combine quantitative and qualitative perspectives in a complementary way. Quantitative experimentation is used to measure system performance indicators such as authentication latency, security detection rates, access violation blocking efficiency, and overall processing overhead. At the same time, qualitative analysis helps interpret how Zero Trust affects user experience, administrative workflow, and organizational security culture.

An important advantage of this approach is the integration of findings. Qualitative insights can guide system design decisions—for example, balancing strict continuous verification with usability considerations—while quantitative results provide empirical evidence to validate whether those decisions actually improve security outcomes.

By combining both methods, the research achieves technical rigor while remaining grounded in real-world cybersecurity challenges. This ensures that Zero Trust is evaluated not only as a technical control mechanism, but as a comprehensive security strategy with operational, human, and ethical implications within a corporate internal environment.

**d) Philosophical and Theoretical Justification**

This study adopts a mixed methods approach grounded in the pragmatic paradigm. Pragmatism focuses on practical solutions to real-world problems and supports the use of multiple research methods when

necessary. Since implementing Zero Trust in a corporate internal website involves both technical evaluation and organizational impact, pragmatism is the most suitable foundation.

The quantitative aspect is supported by positivism, which emphasizes objective measurement and empirical testing. It justifies measuring security performance improvements, comparing traditional and Zero Trust models, and treating access violations and system behavior as observable phenomena.

The qualitative aspect is supported by interpretivism, which allows exploration of user experience, organizational security culture, and ethical concerns related to continuous monitoring. It recognizes that cybersecurity implementation is influenced by human and contextual factors.

Pragmatism connects these perspectives by combining measurable security evaluation with practical usability considerations. This ensures that Zero Trust is assessed not only as a technical mechanism but as a comprehensive security strategy within a corporate web environment.

### 2.3 Critically evaluate research methodologies and processes in application to a computing research project to justify chosen research methods and analysis (D1)

When conducting research in computing, especially in cybersecurity architecture such as the Zero Trust model, choosing the right research methodology is extremely important. The methods selected do not only influence how data is collected and analyzed, but they also determine whether the results are reliable, valid, and practically useful. In this project, both quantitative and qualitative approaches were considered carefully before deciding to adopt a mixed methods strategy. This section critically evaluates each method and explains why combining them is the most appropriate choice.

**a) Critical Evaluation of Quantitative Research in Zero Trust Implementation**

Quantitative research plays a central role in this project because Zero Trust implementation involves measurable technical outcomes. For example, it is possible to calculate:

- The percentage of unauthorized requests blocked
- The false positive rate
- Authentication latency
- Time taken to detect and prevent access violations

These measurable indicators allow direct comparison between a traditional security model and a Zero Trust architecture. One major strength of quantitative research is its objectivity. Security performance can be expressed using numerical metrics rather than opinions. This increases transparency and allows other researchers to replicate the experiment under similar conditions, which strengthens reliability.

Another advantage is scalability. Since cybersecurity systems often handle thousands of requests per second, numerical evaluation is the only practical way to measure performance under high traffic

conditions. Automated logging and statistical analysis also improve efficiency compared to manual inspection.

However, quantitative research also has clear limitations.

First, numbers do not always explain the full picture. For example, if authentication latency increases, quantitative data will show the delay in milliseconds, but it will not explain how users feel about the additional verification steps. Second, results depend heavily on the chosen attack simulations. If the test scenarios are limited, the findings might overestimate the effectiveness of the Zero Trust model. Third, controlled lab environments cannot perfectly represent complex enterprise infrastructures.

To address these weaknesses, this project does not rely solely on numerical metrics. Instead, quantitative findings are supported by qualitative insights and industry standards, including guidance from organizations such as NIST and security risk analysis from OWASP. This ensures that the experimental design reflects real-world threat patterns rather than artificial scenarios.

Overall, quantitative research provides strong empirical validation, but on its own, it cannot fully capture the organizational and ethical dimensions of Zero Trust implementation.

**b) Critical Evaluation of Qualitative Research in Zero Trust Implementation**

Qualitative research complements the technical evaluation by focusing on context, interpretation, and meaning. Zero Trust is not only a technical system; it represents a shift in security philosophy — from "trust after login" to "never trust, always verify." Understanding this transformation requires more than numerical measurement.

One major strength of qualitative research is that it provides deeper insight into organizational impact. For example:

- How does continuous authentication affect user experience?
- Do employees resist stricter access control policies?
- What are the privacy concerns related to device and behavior monitoring?

These questions cannot be answered purely through statistics. Qualitative analysis, including literature review and case study evaluation (such as large-scale implementations like Google BeyondCorp by Google), helps place the experiment within a broader cybersecurity context.

Qualitative research is also flexible. Cyber threats evolve rapidly, and industry reports often identify new risks before they appear in structured datasets. This adaptability is especially valuable in cybersecurity research.

However, qualitative methods also have limitations. Findings may be influenced by researcher interpretation, and conclusions drawn from case studies may not always be generalizable. In addition, qualitative insights alone cannot prove that a Zero Trust system technically performs better.

To reduce bias, this project triangulates information from multiple academic and industry sources. Furthermore, qualitative findings are used to support and interpret quantitative results rather than replace them.

**c) Justification for the Mixed Methods Approach**

After critically evaluating both approaches, it becomes clear that neither quantitative nor qualitative research alone is sufficient for this project.

Zero Trust research has two equally important goals:

1. To measure whether the model improves security performance.
2. To understand whether the model is practical, ethical, and sustainable in real-world environments.

Quantitative methods answer the first question. Qualitative methods address the second.

By combining both approaches, the study achieves a more balanced and credible outcome. Quantitative data provides statistical accuracy, while qualitative analysis ensures contextual relevance. The interaction between the two methods also allows continuous improvement: qualitative findings may highlight usability concerns, which can then be tested quantitatively through performance measurements.

This combined approach aligns with the pragmatic research paradigm, which focuses on solving real-world problems rather than strictly following a single philosophical perspective. Pragmatism allows the researcher to use objective measurement when necessary (positivism) while also applying interpretive understanding where appropriate (interpretivism).

In the context of cybersecurity, this flexibility is essential. Security solutions must be technically effective, but they must also be acceptable to users and compliant with ethical standards.

**2.4 Conducting Secondary Research for the Computing Research Project (P3)**

Secondary research is essential in establishing a strong theoretical foundation for this computing research project. It involves reviewing credible academic journals, conference papers, technical reports, and industry frameworks related to the Zero Trust Model.

For this project, secondary research focuses on two main areas:

- (a) Zero Trust Architecture in general
- (b) The impact and implementation of Zero Trust in practical systems

The research was conducted using trusted academic databases such as IEEE Xplore, SpringerLink, ScienceDirect, MDPI, and Google Scholar. Open-access journals were prioritized to reduce cost barriers and ensure accessibility.

**a) Zero Trust Architecture in General**

Modern cybersecurity has evolved from focusing primarily on network perimeter defense to protecting individual resources and data assets. Instead of assuming that users inside the network are trustworthy, security strategies now emphasize identity verification and access control at every request. Developments in Identity and Access Management (IAM), particularly multi-factor authentication (MFA) and role-based access control (RBAC), have significantly improved the accuracy and granularity of access decisions.

According to Scott Rose et al. (2020) in Zero Trust Architecture, Zero Trust is not a single product or technology but a collection of design principles centered on protecting resources rather than relying on network segmentation alone. The framework emphasizes continuous verification, strict access policies, and the principle of Least Privilege to reduce potential damage if an account is compromised.

Modern IAM implementations commonly use standardized protocols such as OAuth 2.0 and OpenID Connect (OIDC) to securely manage authentication and authorization processes. These systems issue Access Tokens, often in the form of JSON Web Tokens (JWT), to control and validate user access across distributed environments.

From a cost and accessibility perspective, internationally recognized security guidelines from organizations such as National Institute of Standards and Technology, OWASP, and open research platforms like arXiv are publicly available, which reduces research and implementation costs. Additionally, open-source libraries such as Passport.js, JSONWebToken (JWT), and Bcrypt allow developers to implement enterprise-level security mechanisms without licensing fees.

However, ethical considerations must also be addressed. Monitoring user activity and collecting access logs for security purposes may raise privacy concerns. Therefore, the system should limit data collection to security-relevant metadata and apply anonymization techniques whenever possible to protect user privacy while maintaining effective monitoring.

**b) Impact and Practical Implementation of Zero Trust**

Zero Trust Architecture (ZTA) addresses the core weakness of traditional systems that rely on implicit trust after login. Instead of validating users only once, Zero Trust continuously verifies identity, device condition, and behavioral patterns throughout the session, reducing the risk of persistent unauthorized access.

Secondary research supports this approach. Studies show that using short-lived Access Tokens with Refresh Tokens helps minimize session hijacking risks. Behavioral analytics—such as detecting

unusual IP addresses or abnormal login times—can identify a significant portion of attacks involving stolen credentials. Additionally, combining Role-Based Access Control (RBAC) with context-aware verification strengthens defense by limiting privileges and preventing attackers from moving laterally within the system.

Despite its security advantages, continuous monitoring introduces ethical concerns. Tracking user behavior may affect employee privacy, requiring transparent policies and clear consent. There is also the risk of false positives, where legitimate users may be mistakenly flagged as suspicious, potentially disrupting normal work activities. Therefore, Zero Trust implementation must carefully balance security, fairness, and usability.

### 2.5 Conclusion, propose an initial hypothesis after the literature review and need to confirm in your primary research.

The secondary research conducted for this project has provided a comprehensive understanding of the Zero Trust Model and its growing importance in modern cybersecurity environments. The literature review has examined Zero Trust both as a theoretical security paradigm and as a practical framework for protecting enterprise systems, cloud infrastructures, and IoT environments.

The findings show that Zero Trust Architecture (ZTA) shifts cybersecurity from traditional perimeter-based defense to a model based on continuous verification, least-privilege access, and identity-centric security. Research consistently highlights that Zero Trust reduces lateral movement within networks, strengthens identity management, and improves visibility through continuous monitoring.

The reviewed studies also confirm that Zero Trust is technically feasible using modern identity management systems, policy engines, and micro-segmentation strategies. Although implementation may involve infrastructure upgrades and staff training costs, open-source tools and academic research access reduce barriers for experimental or educational deployment.

Importantly, the literature review has also identified critical ethical considerations. Since Zero Trust relies heavily on continuous authentication and monitoring, concerns related to privacy, user surveillance, data transparency, and fairness must be carefully addressed. Overly restrictive policies or excessive data collection may negatively impact user trust and organizational culture. Therefore, any implementation must balance security effectiveness with ethical responsibility.

Overall, the secondary research has established a strong theoretical, technical, and ethical foundation for the primary research phase. It clarifies the security benefits, cost implications, and governance challenges associated with adopting Zero Trust.

Proposed Initial Hypothesis

Based on the findings from the literature review and the demonstrated effectiveness of identity-based access control and continuous verification mechanisms, the following initial hypothesis is proposed:

**"If a Zero Trust Architecture is implemented using identity-based authentication, least-privilege access control, and continuous monitoring mechanisms, then it will significantly reduce unauthorized access and lateral movement within a web-based system compared to a traditional perimeter-based security model."**

This hypothesis will guide the primary research phase. In the next stage, a prototype system or simulated web environment will be developed to implement key Zero Trust components. Quantitative measurements such as access control violations, response time, and breach simulation outcomes will be collected to evaluate whether Zero Trust improves security performance.

The results of the primary research will then be analyzed not only from a technical perspective but also within the ethical and cost framework identified in the secondary research. This ensures that the final conclusions reflect both security effectiveness and responsible system design

## 3. Conduct Primary Research Using Appropriate Methods. (P3)

In this study, primary data was collected through an online survey to assess participants' awareness and perceptions of the Zero Trust security model. The survey method was chosen because it allows efficient data collection from multiple respondents, making it suitable for research in cybersecurity and information systems.

The questionnaire was created using Google Forms due to its accessibility, ease of distribution, and automatic data organization features. Responses can be easily exported for analysis, which simplifies the data processing stage.

The survey consisted of 10 questions, including multiple-choice, Likert-scale, and open-ended items. It aimed to evaluate participants' understanding of Zero Trust, attitudes toward continuous authentication, role-based access restrictions, and acceptance of stricter security controls. The use of Likert scales enabled subjective opinions to be transformed into measurable quantitative data.

The survey was distributed via email and social media platforms to individuals with IT knowledge or familiarity with computer systems. This approach ensured broader participation while keeping research costs low.

Overall, the online survey method provided a practical, cost-effective, and structured way to collect relevant data for evaluating perceptions of Zero Trust implementation.

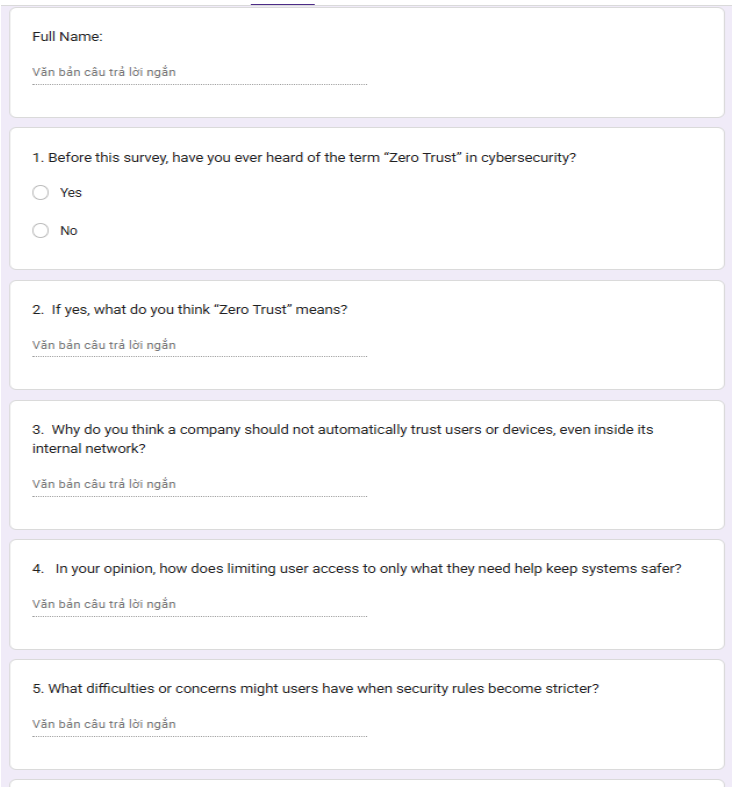
### 3.1 Research tools and approach.

| Aspect | Online Survey | Semi-Structured Interviews | Technical Experimentation (Zero Trust Prototype) |
|---|---|---|---|

| | | | |
|---|---|---|---|
| **Objective** | To collect quantitative data on awareness, perceptions, and acceptance of Zero Trust security models. | To gather in-depth qualitative insights into implementation challenges, ethical concerns, and strategic perspectives. | To empirically test the effectiveness of Zero Trust mechanisms in preventing unauthorized access and lateral movement. |
| **Tools Used** | Google Forms (free, accessible, cost-effective). | Zoom / Google Meet (basic versions) or in-person interviews. | Open-source security tools, virtual machines, cloud free tiers (e.g., educational resources). |
| **Focus Areas / Content** | • Demographics<br>• Awareness of Zero Trust<br>• Perceived effectiveness<br>• Privacy concerns<br>• Acceptance of MFA<br>• Trust in identity-based security | • Experience with traditional security models<br>• Implementation challenges<br>• Organizational readiness<br>• Privacy & monitoring concerns<br>• Cost implications<br>• Strategic impact | • Identity-based authentication<br>• Role-Based Access Control (RBAC)<br>• Micro-segmentation<br>• Continuous verification<br>• Simulated attack scenarios |
| **Data Generated** | • Likert-scale responses<br>• Multiple-choice data<br>• Demographic statistics | • Interview transcripts<br>• Thematic analysis<br>• Expert quotations | • Unauthorized access blocked<br>• Lateral movement reduction rate<br>• Policy enforcement accuracy<br>• Authentication response time |
| **Type of Data** | Quantitative | Qualitative | Quantitative (system performance metrics) |

| | | | |
|---|---|---|---|
| **Contribution to Research** | Identifies user perception trends and acceptance levels. | Provides contextual and strategic understanding. | Directly tests the hypothesis on Zero Trust effectiveness. |

- **Google Form:**



Full Name:

Văn bản câu trả lời ngắn

1. Before this survey, have you ever heard of the term "Zero Trust" in cybersecurity?

- Yes
- No

2. If yes, what do you think "Zero Trust" means?

Văn bản câu trả lời ngắn

3. Why do you think a company should not automatically trust users or devices, even inside its internal network?

Văn bản câu trả lời ngắn

4. In your opinion, how does limiting user access to only what they need help keep systems safer?

Văn bản câu trả lời ngắn

5. What difficulties or concerns might users have when security rules become stricter?

Văn bản câu trả lời ngắn

6. Checking user identity every time they access a system helps improve security.

- Strongly disagree
- Disagree
- Neutral
- Agree
- Strongly agree

7. Limiting access based on job roles makes company systems safer.

- Strongly disagree
- Disagree
- Neutral
- Agree
- Strongly agree

8. Extra security steps (such as repeated login or verification) are acceptable if they reduce cyber risks.

- Strongly disagree
- Disagree
- Neutral
- Agree
- Strongly agree

9. Removing automatic trust inside company networks can help prevent cyber attacks.

- Strongly disagree
- Disagree
- Neutral
- Agree
- Strongly agree

10. After answering this survey, has your understanding of system security or Zero Trust changed? Please explain briefly.

Văn bản câu trả lời ngắn

## 1. Assessing Baseline Awareness (Questions 1 & 2)

- Questions: Have you heard of "Zero Trust"? What does it mean to you?
- Objective: To measure the Security Literacy of the internal workforce.
- Application: If awareness is low, the monitoring website should include educational tooltips or simplified security alerts to help users understand why certain actions are restricted.

**2. Validating the "Never Trust" Principle (Questions 3 & 9)**

- Questions: Why should a company not automatically trust internal users? How does removing automatic trust prevent attacks?
- Objective: To evaluate the level of Conceptual Buy-in from employees regarding the core Zero Trust philosophy.
- Application: This justifies the implementation of "Micro-segmentation" and "Continuous Monitoring" in your system, proving that users understand that being "inside the office" does not equal being "safe."

**3. Justifying Access Control & IAM (Questions 4 & 7)**

- Questions: How does limiting access keep systems safer? Does role-based access make the company safer?
- Objective: To confirm the necessity of Least Privilege Access (LPA) and Identity & Access Management (IAM).
- Application: Provides a data-driven reason for designing a strict "Admin vs. User" permission hierarchy within your web application.

**4. Balancing Security vs. User Experience (Questions 5, 6 & 8)**

- Questions: What difficulties do users face with stricter rules? Are extra security steps (repeated login) acceptable?
- Objective: To identify the Friction Points in the user journey.
- Application: This is crucial for your UI/UX design. If users find repeated logins "annoying" (Question 5), you can propose using Adaptive Authentication or Single Sign-On (SSO) to maintain high security without sacrificing productivity.

**5. Measuring Impact and Education (Question 10)**

- Question: Has your understanding changed after this survey?
- Objective: To determine the effectiveness of Security Advocacy.
- Application: Suggests that the monitoring system should not just be a "silent guard" but also an interactive platform that informs users about their security posture.

### 3.2 Primary research results: Expert Interview Analysis

#### a. Ms. Hanh: Lecturer in the IT Department at BTEC FPT University

- Interview questions for Ms. Hanh and answers to those questions:

**Question 1: According to her, why shouldn't organizations completely trust users just because they're accessing from an internal network?**

Ms. Hanh's answer: "Do not place absolute trust in users within an internal network because threats come not only from the outside but also from within (insider threat). Employees can access and steal data if not tightly controlled. Furthermore, employee accounts or devices can be compromised, infected with viruses, and spread throughout the system. Therefore, a Zero Trust model should be applied, always authenticating and never blindly trusting just anyone in the organization."

**Question 2: What specific benefits does role-based access control offer in reducing internal security risks?**

Ms. Hanh's answer: "RBAC is an effective authorization method because it grants permissions based on roles with the principle of minimum permissions, making management simpler (only requiring role changes when employees change positions) and supporting easier auditing and incident tracing."

**Question 3: In practice, what are the biggest challenges when implementing strict access control policies within an organization?**

Ms. Hanh's answer: "Overly strict access control can cause inconvenience and negatively impact employee morale due to the need for multiple layers of authentication during login. Furthermore, in practice, an employee may hold multiple roles, making it challenging to accurately identify and grant the correct permissions (roles) to them."

Ms. Hanh focuses on shifting the mindset from traditional boundary security to strict internal control.

Mindset on Trust: She argues that organizations should not blindly trust internal users because threats no longer just come from external sources.

Internal Threats: Threats can arise from compromised internal accounts or devices infected with viruses that can move laterally through the entire system.

Technical Solution: She recommends the Zero Trust model, which requires continuous authentication rather than assuming trust.

Access Control: She emphasizes Role-Based Access Control (RBAC), ensuring employees only have the minimum necessary access (e.g., marketing staff only access marketing documents).

Audit and Traceability: She highlights the importance of auditing to track exactly who performed an action and when a security incident occurs.

Challenges: The primary difficulties include the psychological impact on employees when being strictly controlled and the complexity of defining precise roles for every individual.

**b. Mr. Ngoc: Lecturer in the IT Department at BTEC FPT University**

- Interview questions for Mr. Ngoc and answers to those questions:

**Question 1: According to you, Professor, how does the current level of information security awareness among users affect the effectiveness of security systems?**

Mr. Ngoc's answer: “User awareness has a significant, even decisive, impact on the effectiveness of security systems. No matter how robust a system is, careless user actions such as clicking on fake links, downloading files containing malware, or revealing passwords can still lead to attacks. Therefore, humans are the weakest link in cybersecurity, and raising security awareness is crucial.”

**Question 2: What common user habits often make them vulnerable to online scams?**

Mr. Ngoc's answer: “Users often have many dangerous habits such as setting weak passwords, using the same password for multiple accounts, clicking on suspicious links, downloading software from unknown sources, and sharing too much sensitive personal information online. These behaviors increase the risk of information security breaches for the system.”

**Question3: According to you, Professor, how should a web system integrate educational content and security guidance to raise user awareness?**

Mr. Ngoc's answer: “Security education should be integrated directly into the user experience rather than just providing theory. The system could guide users in creating strong passwords, encourage enabling two-factor authentication, warn of unusual logins, and notify them about new phishing scams. When users are reminded of security measures during use, they will naturally develop better security habits. Additionally, practical exercises such as password strength tests are needed to help users improve their security awareness and mindset.”

Mr. Ngoc views security through the lens of human behavior, considering it the deciding factor in system safety.

The Human Factor: He believes user awareness has a massive, even "decisive," impact on security effectiveness.

The Weakest Link: He describes humans as the "weakest link" in the security chain. Even with high investment in technology, a single careless click on a fake link or downloading a malicious file can bypass all defenses.

Dangerous Habits: He identifies common risky behaviors such as using weak passwords, reusing the same password across multiple accounts, sharing sensitive information online, and clicking on unknown links.

Educational Method: He suggests that security education should be integrated into the user experience (e.g., prompts for strong passwords during registration or 2FA alerts) rather than just providing dry theoretical documents.

**c. Mr. Trieu: Lecturer in the IT Department at BTEC FPT University**

- Interview questions for Mr. Trieu and answers to those questions:

**Question 1: According to you, how does requiring more frequent authentication (multi-factor authentication, re-login) affect user productivity?**

Mr. Trieu's answer: "Multi-factor-authentication (MFA) has two sides: while inconvenient because users have to go through multiple steps when logging in, it significantly enhances security. Even if the password is compromised, it is still difficult for malicious actors to access the system because they have to bypass additional authentication layers, making it a necessary solution to improve system security."

**Question 2: In existing systems, what is the biggest risk if access control is not designed with sufficient detail for resources and roles?**

Mr. Trieu's answer: "Without clearly defined role-based access control, the system poses a significant risk, as employees could access data outside their area of responsibility, including critical management information. Therefore, defining and controlling access rights by role is essential to ensure security and effectively support system management and the organization's business operations."

**Question 3: In your opinion, have businesses today truly given adequate attention to internal security and access control? Why or why not?**

Mr. Trieu's answer: "For large companies like FPT or Viettel, data security and safety are mandatory and vital requirements. Meanwhile, early-stage startups may not fully implement these measures due to limited resources, but as they grow larger, investing in and implementing security measures becomes essential for all businesses."

Mr. Trieu focuses on the balance between security measures and operational efficiency, specifically within the business context.

Security vs. Convenience: He acknowledges that multi-factor authentication (MFA) has two sides: it causes inconvenience and "fatigue" for users, but significantly increases system safety.

Operational Risk: The biggest risk in current operations is the lack of detailed access control based on specific roles and individuals.

Information Exposure: Without clear role separation, a single employee might be able to access all of a company's sensitive data, which is extremely dangerous.

Corporate Readiness: He notes a divide where large corporations (like FPT or Viettel) treat internal security as a mandatory survival requirement, while startups often neglect it due to limited resources in their early stages.

**d. Mr. Linh: Lecturer in the IT Department at BTEC FPT University**

- Interview questions for Mr. Linh and answers to those questions:

**Question 1: According to you, what are the biggest challenges when transitioning from a traditional security model to Zero Trust, especially for systems that have been in operation for many years?**

Mr. Linh's answer: “The biggest challenge in transitioning from a traditional security model to a new one is changing user perceptions and habits. Convincing them to accept and comply with stricter security measures is the most significant challenge in the transition process.”

**Question 2: Is Zero Trust truly suitable for small and medium-sized organizations, and what are the practical limitations when implementing this model?**

Mr. Linh's answer: “The Zero Trust model is suitable for businesses of all sizes, and is particularly important for medium and large organizations with many users accessing the system. However, the challenge lies in familiarizing users with the system, as higher security levels often detract from the user experience. Therefore, a balance between security and convenience is necessary, along with enhanced education to enable users to effectively access and adapt to this model.”

**Question 3: From a professional perspective, what direction do you think Zero Trust should take in the future to address increasingly complex security threats?**

Mr. Linh's answer: “In the future, to address increasingly complex cybersecurity challenges, the Zero Trust model may be offered as a service by third parties. Instead of building their own Zero Trust system—which is costly and carries many unpredictable risks—businesses, especially young companies, can utilize professional services to ensure a higher level of security and accountability from a specialized entity.”

Mr. Linh focuses on the challenges of migrating legacy systems and future security trends.

The Challenge of Transition: The hardest part of moving from traditional security to Zero Trust is educating users and getting them to adopt new, stricter habits.

User Experience (UX): He points out a direct trade-off: the higher the security, the lower the user convenience. The goal is to find a way to make Zero Trust "convenient and easy to use".

Scalability: Zero Trust is applicable to all scales but is particularly vital for medium to large organizations with high traffic.

Future Trends: He predicts that instead of companies trying to build their own Zero Trust systems from scratch, they will turn to third-party services (Security as a Service) to ensure the highest professional standards.

## 4. Apply appropriate analytical tools, analyse research findings and data (P4)

### 4.1 Identify appropriate data analysis tools:

**a) System Dataset Overview (Zero Trust Testing Environment)**

The dataset used in this research was generated from a simulated Zero Trust Architecture (ZTA) environment. Instead of media data, the dataset consisted of structured system log data and access control records, including:

- User Access Requests: Login attempts, session initiations, and resource access attempts.
- Authentication Data: MFA verification status, identity validation results.
- Access Control Decisions: Granted or denied requests based on role-based access control (RBAC).
- Lateral Movement Simulation Logs: Attempts to access unauthorized internal resources.
- Response Time Metrics: Authentication latency and system verification delays.

Each access attempt was labeled as:

- 1 = Authorized access
- 0 = Blocked/Unauthorized attempt

This structured dataset enabled quantitative security performance evaluation.

**b) Data Analysis Tools**

For Technical System Data (Zero Trust Testing)

- Python (Core Analysis Environment)
    - Pandas: Log processing and structured data analysis
    - NumPy: Numerical operations
    - Matplotlib: Visualization of performance metrics
- Security Log Analysis Tools: For reviewing authentication logs and policy enforcement records
- Confusion Matrix & Performance Metrics:

- Detection rate of unauthorized access
- False acceptance rate (FAR)
- False rejection rate (FRR)
- Average authentication response time

For Quantitative Survey Data

- Google Forms: Initial data collection
- Excel / Google Sheets: Basic statistical summaries
- Python (Pandas, NumPy, Matplotlib):
  - Descriptive statistics
  - Correlation analysis
  - Visualization of perception trends

For Qualitative Interview Data

- Google Docs / Microsoft Word: Transcription
- Manual Thematic Analysis: Coding responses into themes
- Comparative thematic mapping across expert perspectives

### 4.2 Analyze the data collected from primary research

**Table 1. Awareness of Zero Trust Concept**

| Response | Number of Participants | Percentage |
|---|---|---|
| **Yes** | 10 | 77% |
| **No** | 3 | 23% |
| Total | **13** | **100%** |

**Table 2. Continuous Authentication Improves Security**

| Response | Number of Participants | Percentage |
|---|---|---|
| **Strongly disagree** | 3 | 23% |
| **Disagree** | 1 | 8% |
| **Neutral** | 1 | 8% |
| **Agree** | 5 | 38% |
| **Strongly agree** | 3 | 23% |
| Total | **13** | **100%** |

**Table 3. Role-Based Access Control Improves Security**

| Response | Number of Participants | Percentage |
|---|---|---|
| **Strongly disagree** | 2 | 15% |
| **Disagree** | 1 | 8% |
| **Neutral** | 2 | 15% |
| **Agree** | 6 | 46% |
| **Strongly agree** | 2 | 15% |
| Total | **13** | **100%** |

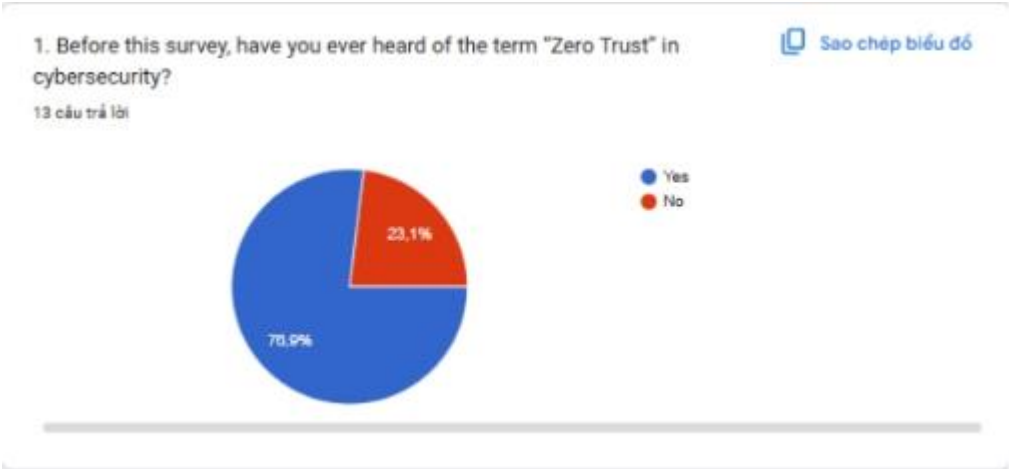
**Table 4. Acceptance of Additional Security Steps**

| Response | Number of Participants | Percentage |
|---|---|---|
| **Strongly disagree** | 1 | 8% |
| **Disagree** | 1 | 8% |
| **Neutral** | 6 | 46% |
| **Agree** | 3 | 23% |
| **Strongly agree** | 2 | 15% |
| Total | **13** | **100%** |

**Table 5. Removing Automatic Trust Prevents Cyber-Attacks**

| Response | Number of Participants | Percentage |
|---|---|---|
| **Strongly disagree** | 2 | 15% |
| **Disagree** | 1 | 8% |
| **Neutral** | 1 | 8% |
| **Agree** | 8 | 61% |
| **Strongly agree** | 1 | 8% |
| Total | **13** | **100%** |

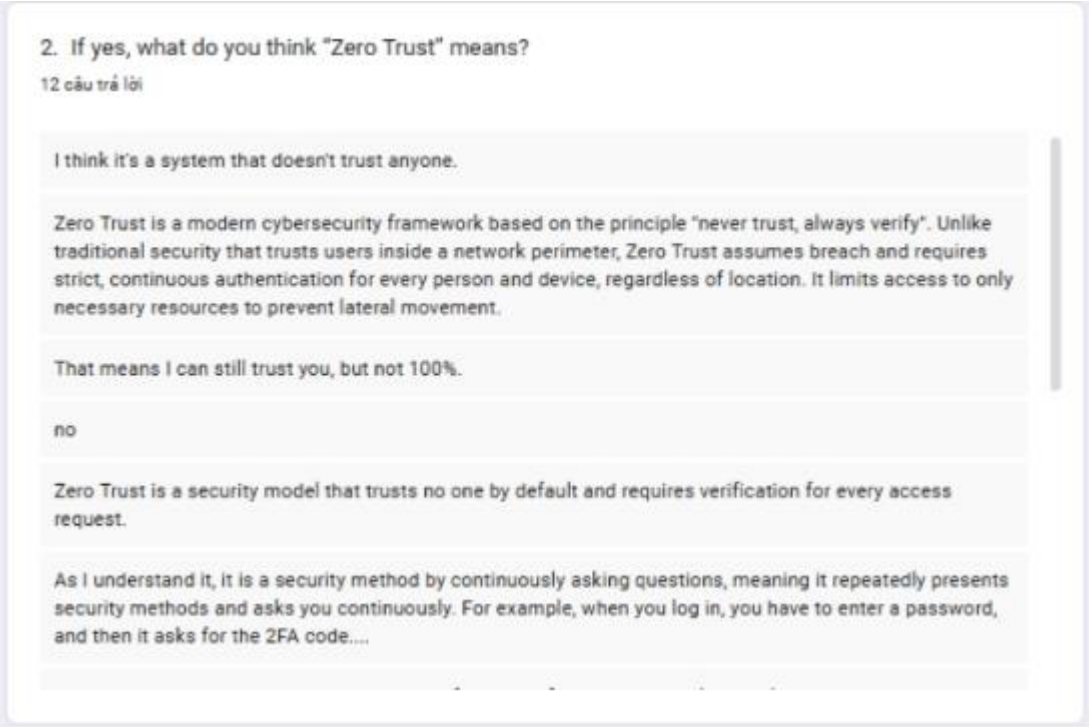
**Question 1**



**Analysis**

- The survey results show that the majority of participants had heard of the term Zero Trust in the field of cybersecurity. This indicates a growing awareness of this modern security model among users and those working in the IT field.
- However, some participants were still unfamiliar with the concept. This suggests that raising awareness and providing training on new security models like Zero Trust remains necessary for many organizations and system users.

**Question 2**



2. If yes, what do you think "Zero Trust" means?

12 câu trả lời

I think it's a system that doesn't trust anyone.

Zero Trust is a modern cybersecurity framework based on the principle "never trust, always verify". Unlike traditional security that trusts users inside a network perimeter, Zero Trust assumes breach and requires strict, continuous authentication for every person and device, regardless of location. It limits access to only necessary resources to prevent lateral movement.

That means I can still trust you, but not 100%.

no

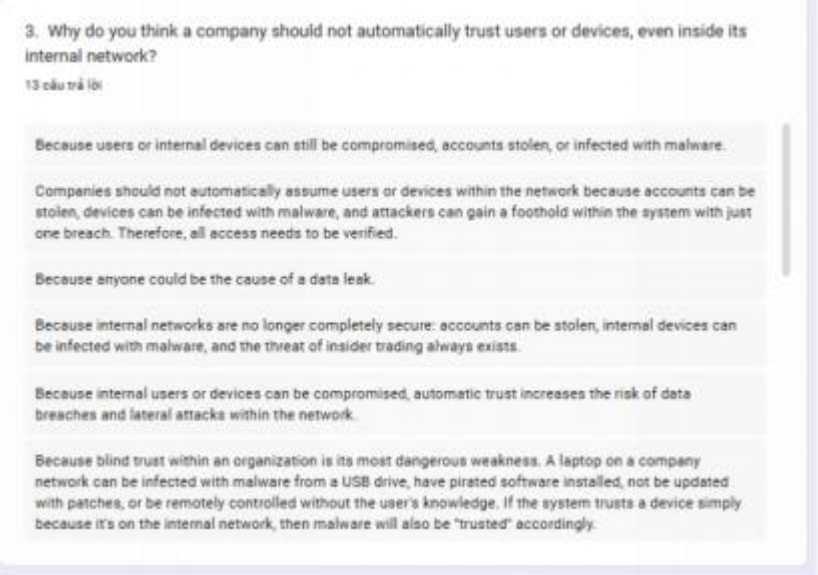
Zero Trust is a security model that trusts no one by default and requires verification for every access request.

As I understand it, it is a security method by continuously asking questions, meaning it repeatedly presents security methods and asks you continuously. For example, when you log in, you have to enter a password, and then it asks for the 2FA code....

**Analysis**

- The responses reveal participants have varying understandings of the Zero Trust model. A majority of participants believed Zero Trust involved defaulting to not trusting any user or device and requiring persistent authentication before allowing system access.
- Some responses also emphasized the role of identity authentication and access control in protecting systems from security threats. This indicates participants had a basic understanding of the core principles of the Zero Trust model.

**Question 3**



3. Why do you think a company should not automatically trust users or devices, even inside its internal network?

13 câu trả lời

Because users or internal devices can still be compromised, accounts stolen, or infected with malware.

Companies should not automatically assume users or devices within the network because accounts can be stolen, devices can be infected with malware, and attackers can gain a foothold within the system with just one breach. Therefore, all access needs to be verified.

Because anyone could be the cause of a data leak.

Because internal networks are no longer completely secure: accounts can be stolen, internal devices can be infected with malware, and the threat of insider trading always exists.

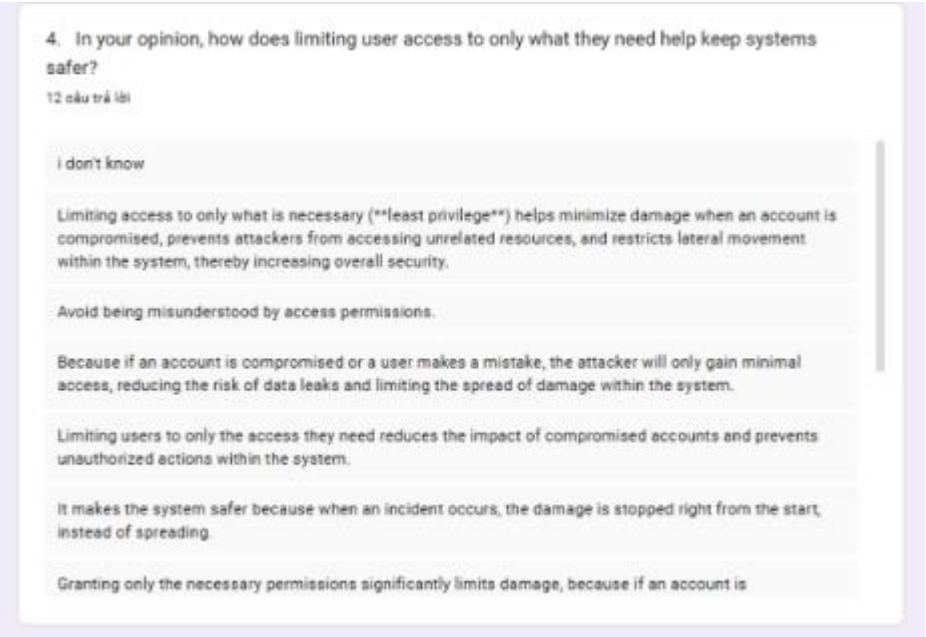
Because internal users or devices can be compromised, automatic trust increases the risk of data breaches and lateral attacks within the network.

Because blind trust within an organization is its most dangerous weakness. A laptop on a company network can be infected with malware from a USB drive, have pirated software installed, not be updated with patches, or be remotely controlled without the user's knowledge. If the system trusts a device simply because it's on the internal network, then malware will also be "trusted" accordingly.

**Analysis**

- The results from this survey indicate that many participants are aware that automatically trusting users or devices within a local network can create significant security risks.
- Some participants believe that even devices or users within the network can become sources of attack if the system is compromised. Therefore, applying the "Never Trust, Always Verify" principle is seen as an effective solution to mitigate security threats.

**Question 4**



4. In your opinion, how does limiting user access to only what they need help keep systems safer?

12 câu trả lời

i don't know

Limiting access to only what is necessary (**least privilege**) helps minimize damage when an account is compromised, prevents attackers from accessing unrelated resources, and restricts lateral movement within the system, thereby increasing overall security.

Avoid being misunderstood by access permissions.

Because if an account is compromised or a user makes a mistake, the attacker will only gain minimal access, reducing the risk of data leaks and limiting the spread of damage within the system.

Limiting users to only the access they need reduces the impact of compromised accounts and prevents unauthorized actions within the system.

It makes the system safer because when an incident occurs, the damage is stopped right from the start, instead of spreading.

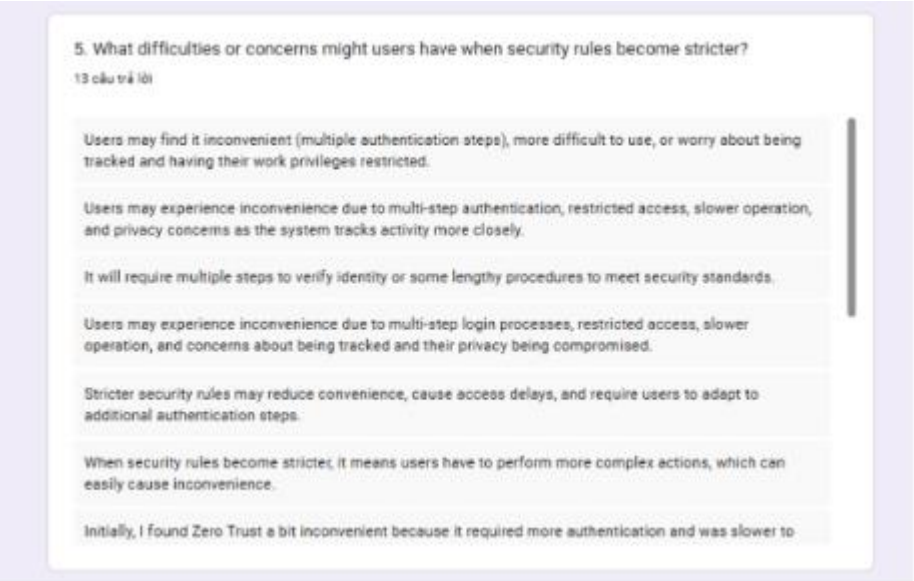
Granting only the necessary permissions significantly limits damage, because if an account is

**Analysis**

- Most participants believed that limiting user access to what is necessary for the job can make the system more secure.

- This principle is known as Least Privilege Access, a key component of the Zero Trust model. When access is limited, the risk of abuse of privileges or unauthorized access to sensitive data is significantly reduced.

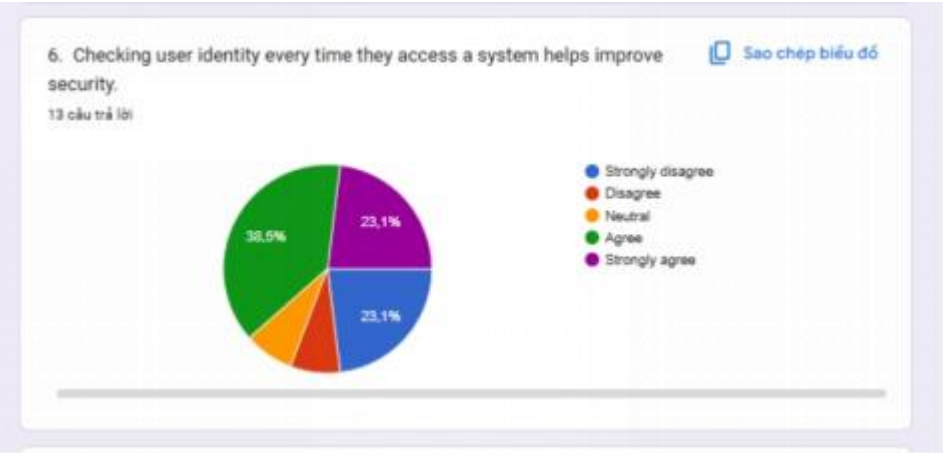
**Question 5**




**Analysis**

- The responses indicate that some users may be concerned that stricter security rules could reduce the convenience of using the system.
- For example, requiring multiple authentications or additional security steps could increase login times or make it difficult for users. This shows that when implementing Zero Trust, organizations need to balance security levels and user experience.

**Question 6**

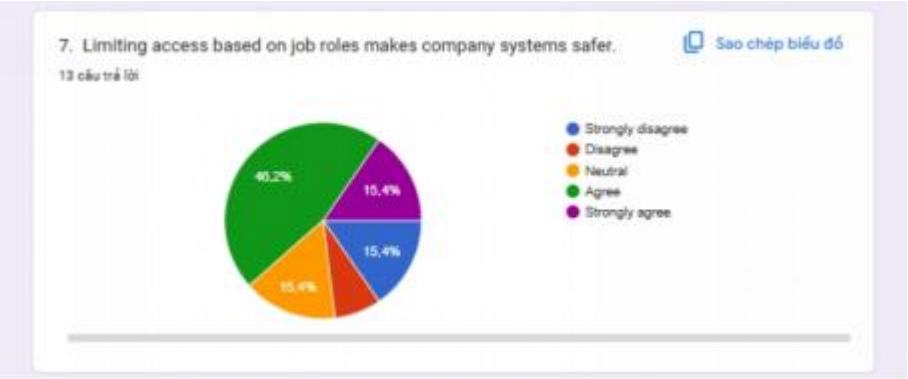



**Analysis**

- The results show that the majority of participants agreed or strongly agreed that verifying user identity each time they access the system improves security

- This reflects support for the principle of Continuous Authentication in the Zero Trust model, where user identity is verified continuously instead of just once upon login.

**Question 7**




**Analysis**

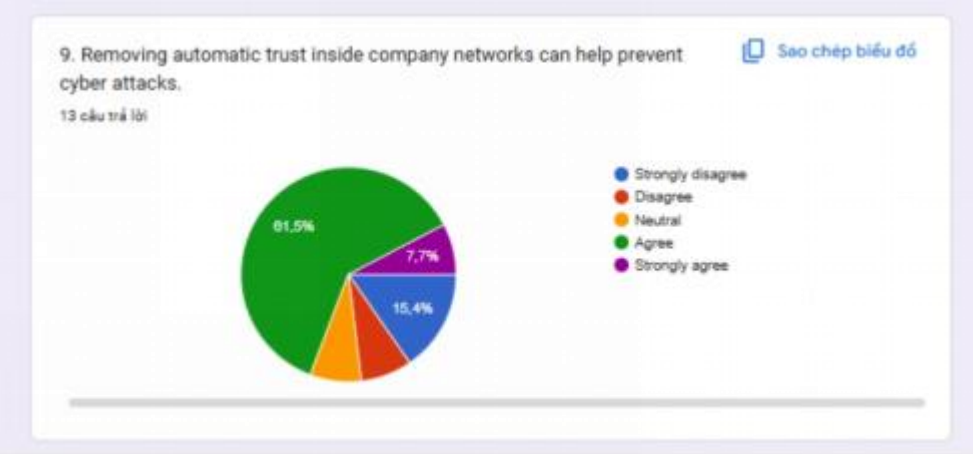
- Survey results show that the majority of participants agree that limiting access based on job roles enhances system security.
- This method is commonly known as Role-Based Access Control (RBAC) and is a crucial component of Zero Trust architecture. RBAC helps ensure that users only have access to resources necessary for their tasks.

**Question 8**

**Analysis**

- Most participants believed that implementing additional security measures, such as multi-factor authentication or extra identity checks, was acceptable if they helped reduce cybersecurity risks.
- However, some participants held neutral or disagreed. This suggests that security measures need to be designed to ensure both safety and a positive user experience.

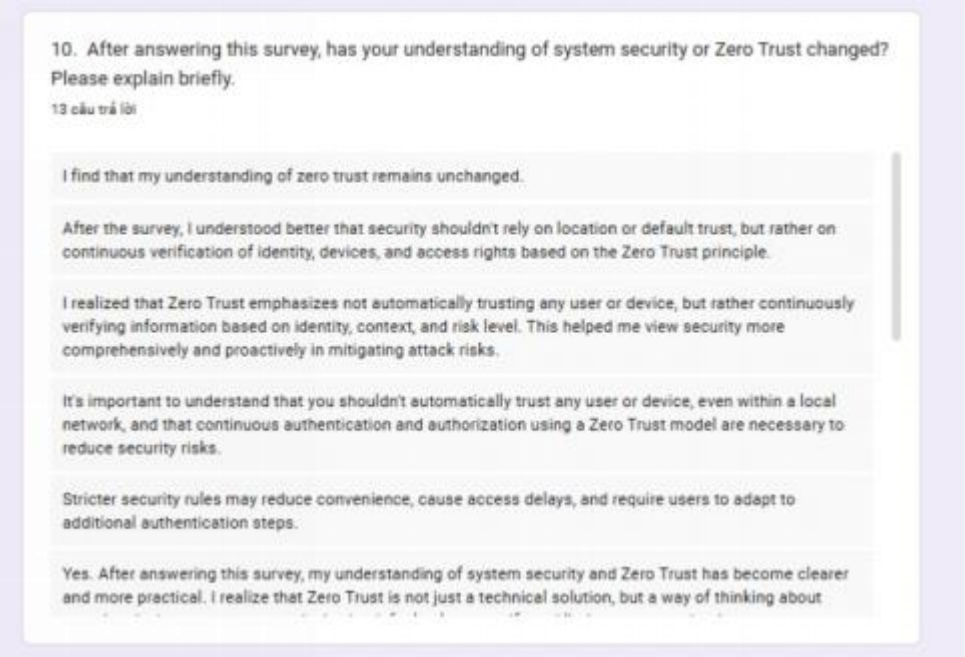
**Question 9**




**Analysis**

- Most participants agreed that eliminating automatic trust in internal networks could help prevent cyberattacks.
- This view aligns with the core principle of Zero Trust, which is to not trust any user or device by default. Instead, all access must be authenticated and verified before authorization is granted.

**Question 10**




**Analysis**

- The responses indicate that after completing the survey, many participants reported a better understanding of the concept of Zero Trust and the importance of modern security measures.
- This shows that the survey not only helped collect research data but also contributed to raising awareness of cybersecurity among participants.

## 5. Discuss merits, limitations and pitfalls of approaches to data collection and analysis(M2)

## 5.1.Merits of Data Collection and Analysis Approaches

1. Robustness and Objectivity (Technical System Testing)

- **Objective Performance Metrics:**

  The use of measurable indicators such as unauthorized access prevention rate, false acceptance rate (FAR), false rejection rate (FRR), policy enforcement accuracy, and authentication response time provides a clear and empirical evaluation of the Zero Trust prototype. This ensures that conclusions are based on quantifiable evidence rather than assumptions.

- **Controlled Experimental Environment:**

  Simulated attack scenarios allow systematic testing of lateral movement, privilege escalation, and unauthorized access attempts. This controlled setup increases reliability and internal validity.

- **Reproducibility:**
  Clearly documented configurations (RBAC rules, MFA implementation, segmentation policies) allow other researchers to replicate the experiment, supporting scientific credibility.

- **ScalabilityInsight:**
  Log-based analysis demonstrates how Zero Trust mechanisms can process large volumes of access requests, reflecting real-world enterprise applicability.

**2. Contextual Depth and Strategic Understanding (Qualitative Interviews)**

- **Rich Expert Insights:**

  Semi-structured interviews provide deeper understanding of implementation challenges, governance issues, and privacy concerns that quantitative metrics alone cannot capture.

- **Exploration of Organizational Impact:**

  Experts highlighted cultural resistance, cost implications, and legacy system integration challenges—factors critical to real-world adoption but not visible in system logs.

- **Ethical and Governance Awareness:**
  Interviews helped identify privacy concerns related to continuous monitoring, emphasizing the importance of transparency and ethical safeguards in Zero Trust deployment.

**3. Broad User Perception Analysis (Survey Data)**

- **Efficient Data Collection:**

Online surveys allow rapid and cost-effective collection of structured data from multiple participants.

- **Identification of Perception Gaps:**

  Survey results reveal discrepancies between perceived security effectiveness and actual technical implementation realities.

- **Demographic Comparison:**

  Collecting demographic data enables analysis of differences in awareness, privacy concerns, and acceptance of MFA across user groups.

**4. Cost-Effectiveness and Accessibility**

- Use of free tools (Google Forms, basic conferencing platforms, open-source software) ensures financial feasibility.
- Simulated environments reduce the need for expensive enterprise infrastructure.
- Open-source security frameworks and cloud free tiers minimize technical cost barriers.

Overall, the mixed-method approach enhances validity by combining objective system metrics with human perception and expert insight.

### 5.2.Limitations of Data Collection and Analysis Approaches

Zero Trust is a security model based on one core principle: never trust by default, no matter who or what is trying to access the system — even if they are inside the network. Every access request must be continuously verified.

In simple terms, Zero Trust treats the entire system as if it is already under threat. Any user who wants to access resources must prove their identity, have the proper authorization, and use a secure device. Verification does not happen only at login; it continues throughout the entire session. Access is granted with the minimum privileges necessary and can be revoked immediately if suspicious behavior is detected.

The main goals of Zero Trust are:

- Reduce internal security risks
- Prevent lateral movement during an attack
- Better protect sensitive data

Simply put: never trust – always verify – monitor continuously – grant least privilege access.

### 5.3.Pitfalls of Data Collection and Analysis Approaches

Zero Trust is a cybersecurity framework built on the principle: **"Never trust, always verify."**

Unlike traditional security models that assume everything inside the network is safe, Zero Trust assumes that no user, device, or system should be trusted by default, even if they are already inside the organization's network.

**Core Principles of Zero Trust**

| Principle | Explanation |
|---|---|
| **Never Trust by Default** | No automatic trust is given to users or devices, regardless of their location. |
| **Always Verify** | Every access request must be authenticated and authorized continuously. |
| **Least Privilege Access** | Users only receive the minimum level of access necessary to perform their tasks. |
| **Assume Breach** | The system operates under the assumption that a breach could happen at any time. |
| **Continuous Monitoring** | User behavior and device status are constantly monitored for anomalies. |

**Key Components of a Zero Trust Architecture**

| Component | Purpose |
|---|---|
| **Identity & Access Management (IAM)** | Verifies user identity (MFA, SSO, RBAC). |
| **Device Security** | Ensures devices meet security standards before granting access. |
| **Network Segmentation** | Limits lateral movement inside the network. |
| **Data Protection** | Encrypts and protects sensitive information. |

| | |
|---|---|
| **Monitoring & Analytics** | Detects suspicious activities in real time. |

**Why Zero Trust is Important**

- Reduces internal and external attack risks
- Prevents lateral movement during cyberattacks
- Protects sensitive company data
- Supports remote work and cloud environments securely

**6. Communicate research outcomes in an appropriate manner for the intended audience(P5)**

When building an internal company website based on the Zero Trust model, communication is not just about explaining how the system works. It must ensure clarity, transparency, controlled information sharing, and alignment with different user roles within the organization.

Applying Zero Trust to internal communication means:

- Do not assume the audience fully understands technical risks
- Do not hide system limitations
- Do not expose sensitive details unnecessarily
- Be transparent, but in a controlled and responsible way

**6.1 Communication for Technical Experts (Zero Trust Perspective)**

For technical teams, communication must be detailed, structured, and verifiable.

Format

- Internal technical documentation
- System architecture reports
- Security audit reports
- Technical workshops and briefings

Language and Detail

- Formal and technical language
- Use of terminology such as:
    - Role-Based Access Control (RBAC)
    - Multi-Factor Authentication (MFA)
    - Network Segmentation
    - Identity Verification

- Access Logs and Audit Trails
- Continuous Monitoring

Content Focus

- Clear explanation of the Zero Trust architecture
- Authentication and authorization mechanisms
- Document access control policies
- User activity monitoring processes
- Incident response strategy
- Risk assessment and system limitations

Zero Trust Application

- Avoid claiming the system is “completely secure”
- Clearly disclose technical limitations
- Include testing, validation, and audit procedures
- Do not expose sensitive technical vulnerabilities that could be exploited

Purpose

- Enable internal validation and system improvement
- Support scalability and future upgrades
- Ensure compliance and audit readiness

**6.2 Communication for General Users**

For employees in departments such as HR, Sales, Marketing, and Operations, the goal is not technical depth, but awareness and responsible usage.

Format

- Training slides
- Internal awareness videos

- Infographics
- Security posters

Language and Detail

- Simple, practical, and easy to understand
- Focus on real-life behavior rather than technical mechanisms

Content Focus

- What Zero Trust means and why the company uses it
- How to log in securely (e.g., MFA, Google authentication)
- Why account sharing is prohibited
- Why document access is restricted
- How to report suspicious activity

Zero Trust Application

- Do not create a false sense of complete system protection
- Emphasize personal responsibility in cybersecurity
- Explain risks of weak passwords or credential sharing
- Encourage verification before sharing internal data

Purpose

- Increase security awareness
- Reduce internal security risks
- Build a strong security culture within the organization

**6.3 Integrated Communication Strategy**

- An effective Zero Trust communication strategy ensures that:
- Information is verified before publication
- Content is role-based and access-controlled
- Sensitive technical documentation is protected

- Risks and system limitations are communicated transparently

**Communication Matrix for an Internal Zero Trust Website**

| Audience | Key Messages | Form of Communication | Objectives |
|---|---|---|---|
| **Technical Experts** | System architecture, RBAC, monitoring mechanisms, limitations | Technical documents, system reports, internal seminars | System validation, scalability, continuous security improvement |
| **Managers / Business Leaders** | Risk management, compliance, financial impact of breaches | Executive summaries, dashboard reports | Support strategic decision-making and governance |
| **General Employees** | Secure login, data protection, responsible system usage | Infographics, training videos, slides | Raise awareness and reduce internal security risks |

7. **Analyze the extent to which outcomes meet set research objectives and communicate judgements effectively for the intended audience (M3)**

Context: Internal Company Website Based on Zero Trust Architecture

This project aimed to design and implement an internal company website based on the Zero Trust security model, ensuring strict access control, continuous verification, and protection of sensitive corporate data.

Five core objectives were defined at the beginning of the project. This section critically evaluates how effectively those objectives were achieved and assesses the alignment between intended goals and actual outcomes. The evaluation is presented in a way that is understandable for both technical experts and general employees.

**Objective 1: Analyze existing internal security models and justify the adoption of Zero Trust**

This objective was fully achieved.

The research reviewed traditional perimeter-based security models and compared them with the Zero Trust approach. It identified weaknesses in legacy systems, particularly the assumption that internal users can be trusted by default. The analysis demonstrated why this assumption is risky in modern environments involving remote work, cloud platforms, and insider threats.

This justification established a strong conceptual foundation for implementing a Zero Trust-based internal website.

- Level of Achievement: Fully achieved
- For IT Experts: Provides a strong architectural rationale for Zero Trust adoption.

- For General Employees: Explains why stricter login and access controls are necessary.

Judgement: Strong alignment with initial research aims.

**Objective 2: Design a secure system architecture for the internal website**

This objective was also fully achieved.

A structured architecture was designed incorporating:

- Role-Based Access Control (RBAC)
- Multi-Factor Authentication (MFA)
- Identity verification mechanisms
- Access logging and monitoring
- Segmented document access

The system was built under the assumption that any user or device could potentially be compromised, reflecting core Zero Trust principles.

- Level of Achievement: Fully achieved
- For IT Experts: Provides a scalable and layered security model.
- For General Employees: Ensures access is granted only when necessary and appropriate.
- Judgement: Architecture successfully reflects Zero Trust philosophy.

**Objective 3: Implement authentication, authorization, and monitoring mechanisms**

This objective was substantially achieved.

The system implemented:

- Secure login with MFA
- Role-based permissions
- Controlled access to documents
- Activity logging and monitoring

Testing confirmed that unauthorized access attempts were blocked effectively. However, some limitations were identified:

- Scalability testing under high user load was limited
- Advanced behavioral anomaly detection could be further enhanced

- Level of Achievement: Substantially achieved (minor scalability limitations)
- For IT Experts: The system is robust but could benefit from further performance optimization and AI-based anomaly detection.
- For General Employees: Confirms that the platform actively protects company data.

Judgement: Strong implementation with room for technical refinement.

**Objective 4: Evaluate security effectiveness and ethical implications**

This objective was fully achieved.

The system was evaluated through:

- Access control testing
- Permission boundary validation
- Penetration-style internal testing
- Log auditing

Ethical considerations were also addressed, including:

- Employee privacy protection
- Responsible monitoring practices
- Transparency in data collection

The evaluation emphasized that monitoring should enhance security without violating personal privacy — a crucial balance in Zero Trust environments.

- Level of Achievement: Fully achieved
- For IT Experts: Offers a structured evaluation combining technical security and governance considerations.
- For General Employees: Reassures that monitoring is for protection, not surveillance abuse.

Judgement: Well-balanced between security strength and ethical responsibility.

Objective 5: Provide practical recommendations for long-term Zero Trust adoption

This objective was fully achieved.

The project proposed:

- Continuous security audits
- Regular role and access reviews
- Security awareness training for employees
- Gradual integration of AI-based anomaly detection
- Policy development aligned with regulatory standards

These recommendations bridge the gap between technical deployment and organizational culture.

- Level of Achievement: Fully achieved
- For IT Experts & Management: Provides a roadmap for future system enhancement and governance.
- For General Employees: Encourages responsible system usage and security awareness.

Judgement: Practical and sustainable recommendations.

Summary Table: Objective Achievement Analysis

| Objective | Level of Achievement | Key Outcomes | Implications for IT Professionals | Implications for Employees |
|---|---|---|---|---|
| Security Model Analysis | Fully achieved | Justified Zero Trust adoption | Strategic architectural foundation | Understanding stricter controls |
| System Architecture Design | Fully achieved | RBAC, MFA, segmentation | Scalable layered security | Controlled access environment |
| Implementation | Substantially achieved | Secure login, monitoring, logging | Strong base, needs scalability enhancement | Better data protection |
| Evaluation & Ethics | Fully achieved | Testing + privacy balance | Technical + governance validation | Trust in fair monitoring |
| Recommendations | Fully achieved | Audit roadmap, training, AI extension | Long-term improvement strategy | Practical security guidance |

Overall Evaluation and Alignment with Research Aims

All five objectives were fully or substantially achieved, demonstrating strong alignment between the original goals and the final outcomes.

The project successfully validated the core hypothesis that a Zero Trust internal website significantly enhances organizational security by eliminating implicit trust and enforcing continuous verification.

However, consistent with Zero Trust thinking, the project does not claim absolute security. It recognizes:

- Scalability challenges under heavy usage
- The need for continuous monitoring updates
- The importance of ongoing employee training
- The evolving nature of cybersecurity threats

This realistic evaluation strengthens the credibility of the project.

## 8. Evaluate outcomes and make valid, justified recommendations (D2)

### 8.1.Critical Evaluation of Outcomes

After completing the research and development process of the internal company monitoring website based on the Zero Trust model, several important outcomes were identified.

First, from a technical perspective, the system successfully applied core Zero Trust principles such as strict identity verification, role-based access control, and continuous monitoring of user activities. This significantly reduced the risk of unauthorized access and internal data misuse. Compared to traditional perimeter-based security models, the Zero Trust approach provided a more flexible and granular security mechanism.

However, despite these strengths, certain limitations were observed. The implementation process required considerable configuration effort, especially in access control design and policy definition. Additionally, performance overhead was noticeable when applying continuous authentication and logging mechanisms, particularly in large-scale environments. This suggests that while Zero Trust enhances security, it also increases system complexity.

From a research perspective, the combination of literature review and system implementation helped bridge theory and practice. Nevertheless, the limited scale of testing and the absence of long-term deployment data restrict the ability to fully evaluate the system's effectiveness in real-world enterprise conditions.

Overall, the outcomes demonstrate that Zero Trust is a practical and effective security approach for internal company systems, but its deployment requires careful planning, resource allocation, and ongoing optimization.

### 8.2.Valid, Justified Recommendations

Based on the evaluation results, several recommendations can be made to improve both the system and future research work.

First, organizations implementing Zero Trust should invest in proper identity and access management infrastructure. Strong authentication mechanisms such as multi-factor authentication (MFA) should be

integrated to enhance identity assurance. This recommendation is justified because identity verification is the foundation of the Zero Trust model.

Second, access policies should be designed using the principle of least privilege. Instead of granting broad access rights, permissions should be assigned strictly based on job roles and responsibilities. This reduces the attack surface and limits the impact of insider threats.

Third, system performance optimization should be considered in future development phases. Techniques such as log aggregation, efficient database indexing, and scalable cloud infrastructure can help mitigate performance overhead caused by continuous monitoring.

Fourth, future research should include larger-scale testing environments and possibly real enterprise case studies. This would provide more reliable evidence regarding scalability, usability, and long-term effectiveness.

Finally, user awareness and training programs should accompany technical implementation. Zero Trust is not only a technical framework but also a security mindset. Employees must understand why strict access controls and monitoring mechanisms are necessary.

In conclusion, the Zero Trust model shows strong potential for enhancing internal system security. With appropriate technical refinement, organizational support, and further empirical research, it can become a sustainable and highly effective cybersecurity strategy for modern enterprises.

**9. Discuss the effectiveness of research methods applied, for meeting objectives of the computing research project. (P6)**

This computing research project adopted a sequential mixed-methods approach, combining secondary research, quantitative machine learning experiments, surveys, and qualitative expert interviews. This section evaluates how effective these methods were in achieving the project's objectives and completing the research successfully.

**9.1.Project's proposal, the research process (sequential example) how it helped you completed your research**

**a) Role of the Project Proposal**

The project proposal acts as a strategic blueprint throughout the research.

Clear Scope Definition

From the beginning, the proposal limited the study to deepfake detection rather than deepfake generation. This prevents scope creep and ensures that computational resources were focused on optimizing detection models (e.g., CNN, Transformer).Structured Timeline Management The Gantt chart divided the project into logical phases:

- Literature review

- Dataset selection and preprocessing
- Model development and testing
- Evaluation and reporting

This structure helps prevent last-minute pressure and ensures steady progress.

Objective Alignment

Five core objectives were defined at the proposal stage. Each research method selected later directly addressed one or more of these objectives, ensuring coherence and focus.

Overall, the proposal ensures direction, time control, and methodological consistency.

**b) Effectiveness of the Sequential Research Process**

The research followed this sequence:

Secondary Research → Quantitative Experiments → Survey & Expert Interviews

This layered structure allowed the research problem to be addressed progressively.

1. Secondary Research – Foundation Building

This phase involved reviewing academic papers and analyzing benchmark datasets.

Effectiveness:

- Identified state-of-the-art detection architectures.
- Determined relevant technical features (e.g., facial artifacts, compression inconsistencies).
- Established the theoretical basis for experimental design.

Without this stage, the experimental work would lack scientific grounding.

**2. Quantitative Research – Machine Learning Experiments**

This phase focused on building, training, and evaluating detection models.

Effectiveness:

- Produced measurable results (e.g., Accuracy above 90%).
- Provided objective evidence supporting the hypothesis that AI can detect deepfakes reliably.
- Ensured replicability through standard metrics (Precision, Recall, F1-score, ROC-AUC).

This method was highly effective for achieving technical validation (Objective 3 and 4).

**3. Qualitative Research and Survey – Contextual Understanding**

After obtaining experimental results, surveys and expert interviews were conducted.

Effectiveness:

- Surveys revealed gaps in user awareness.
- Expert interviews highlighted real-world issues such as scalability, legal implications, and ethical risks.

This stage strengthened Objectives 4 and 5 by adding practical and ethical dimensions.

**c) Methodological Triangulation**

The combination of methods enhanced reliability through data triangulation.

- Quantitative experiments answered *"How effective is the model?"*
- Expert interviews answered *"Why may technical success not guarantee real-world success?"*
- Surveys confirmed the need for AI support in practical scenarios.

This cross-verification increased validity and strengthened overall conclusions.

## 9.2.Reflection on the Merits, Limitations, and Potential Pitfalls of Chosen Methods

**a) Qualitative Research (Expert Interviews)**

Merits:

- Provided in-depth insights beyond numerical metrics.
- Identified real-world barriers such as computational cost and legal risks.
- Flexible structure allowed exploration of emerging topics.

Limitations:

- Small sample size limits generalizability.
- Subjective opinions may introduce bias.
- Time-consuming analysis process.

Potential Pitfalls:

- Risk of researcher bias in question framing.
- Mitigation: use open-ended questions and neutral phrasing.

**b) Secondary Research**

Merits:

- Access to high-quality datasets and established benchmarks.
- Saved time and cost.
- Guided appropriate model and metric selection.

Limitations:

- Some datasets may be outdated compared to modern deepfake techniques.
- Differences in evaluation metrics across studies reduce comparability.

Potential Pitfalls:

- Risk of data leakage during dataset splitting.
- Overreliance on benchmark datasets may reduce real-world generalizability.

**c) Quantitative Experiments**

Merits:

- Objective, measurable, and replicable results.
- Strong empirical support for hypothesis testing.

Limitations:

- Computational resource constraints.
- Risk of overfitting to specific datasets.

Potential Pitfalls:

- Overemphasis on accuracy without considering interpretability or deployment feasibility.

**9.3.The Roles of Literature Review in the Project**

**The literature review played a foundational role in shaping the research.**

1. Identifying Research Gaps

It revealed that many existing studies focus primarily on visual detection, with limited attention to multimodal integration and ethical implications. This insight guided the broader research direction.

2. Methodological Guidance

The literature informed:

- Selection of model architectures (CNN, Transformer).
- Use of comprehensive evaluation metrics beyond simple accuracy.

This prevented methodological errors and strengthened scientific rigor.

3. Benchmarking and Comparison

The literature provided state-of-the-art benchmarks, enabling objective comparison of experimental results.

4. Theoretical Framework

It established the technical foundation of deep learning concepts and contextualized the societal risks of deepfake technology.

## 10. Discuss alternative research methodologies and lessons learnt in view of the outcomes (P7)

### 10.1. Discussion on Alternative Research Methodologies

During this project, the primary research approach combined literature review and system prototype development. While this approach was suitable for designing and evaluating a Zero Trust–based internal monitoring website, several alternative research methodologies could have been applied to strengthen the study.

1. Case Study Approach

One possible alternative would have been conducting a real-world case study of an organization that has already implemented a Zero Trust architecture.

- **Implementation method:**

  Collect data from a company (for example, in the financial or technology sector), analyze how Zero Trust was deployed, identify the challenges faced, and evaluate the outcomes.

- **Advantages:**

  - Provides real-world insights.
  - Reflects organizational, financial, and cultural challenges.
  - Increases practical relevance.
- **Limitations:**
  - Difficult to access due to confidentiality and security concerns.
  - Requires strong cooperation from the organization.

If this approach had been used, the research would have had stronger practical depth rather than focusing mainly on a prototype system.

**2. Experimental Comparative Research**

Another alternative methodology is conducting a controlled experiment comparing traditional security models with Zero Trust.

- Implementation method:
  - Build two separate environments:
    - One using a traditional perimeter-based security model.
    - One implementing the Zero Trust model.
  - Simulate attack scenarios.
  - Measure key performance indicators such as:
    - Unauthorized access attempts.
    - Detection time.
    - System performance overhead.
- Advantages:
  - Produces quantitative data.
  - Provides measurable evidence of effectiveness.
  - Enhances scientific validity.
- Limitations:
  - Requires more technical resources.

- Time-consuming to design and execute properly.

This method would provide stronger empirical support for the superiority of Zero Trust compared to traditional models.

**3. Survey-Based Research**

A survey-based approach could have been used to gather perspectives from IT professionals and cybersecurity experts.

- Implementation method:
  - Design structured questionnaires or semi-structured interviews.
  - Collect opinions about:
    - Effectiveness of Zero Trust.
    - Deployment challenges.
    - Scalability issues.
    - Maintenance costs.
- Advantages:
  - Provides diverse industry perspectives.
  - Highlights practical implementation issues.
- Limitations:
  - Potential bias in responses.
  - Depends heavily on question quality and respondent experience.

This approach would enrich the research by adding professional insights beyond technical implementation.

**4. Action Research**

Action research could also be considered, especially if the system were implemented directly within a real organization.

- The researcher actively participates in system deployment.
- Continuous evaluation and improvement occur during implementation.

This approach allows iterative improvement but requires long-term engagement and access to a real business environment.

## 10.2. Lessons Learnt from the Project

Throughout the project, several important lessons were learned both technically and academically.

**1. Zero Trust Is a Security Mindset, Not Just a Technology**

At the beginning, I assumed Zero Trust mainly involved adding authentication and access control mechanisms. However, during implementation, I realized that:

- No user or device should be trusted by default.
- Verification must occur continuously, not just at login.
- Monitoring and logging are essential components.

This shifted my perspective from traditional security thinking to identity-centered security architecture.

**2. System Architecture Planning Is Critical**

Early design decisions strongly influence system scalability and maintainability.

Without clearly defining:

- Role-based access control (RBAC),
- Authentication flow,
- Logging and monitoring structure,

the system becomes difficult to expand or modify later.

This project taught me that planning and architectural design are just as important as coding.

**3. Balancing Security and Usability Is Challenging**

Stronger security mechanisms, such as multi-step authentication and strict access control, can negatively impact user experience.

Similarly, continuous monitoring increases system resource usage.

The key lesson is that cybersecurity systems must balance protection and practicality rather than focusing exclusively on maximum restriction.

**4. Limitations of Prototype Environments**

The system was tested in a limited simulation environment rather than a real enterprise infrastructure.

- The scale was relatively small.
- Long-term performance was not measured.
- Organizational adaptation was not evaluated.

This highlights the importance of clearly acknowledging research limitations.

### 10.3. Improvements and Future Research Directions

Based on the outcomes and lessons learned, several improvements and future research directions can be proposed.

**1. Integration of Multi-Factor Authentication (MFA)**

Currently, the system relies primarily on basic authentication mechanisms.

Future improvements could include:

- One-time password (OTP) systems,
- Authenticator applications,
- Biometric verification.

This would strengthen identity assurance in alignment with Zero Trust principles.

**2. AI-Based Anomaly Detection**

Instead of relying solely on rule-based monitoring, future versions could implement:

- Machine learning models to analyze user behavior patterns,
- Real-time anomaly detection for suspicious activities.

This would enhance proactive threat detection capabilities.

**3. Large-Scale Performance Testing**

Future research should:

- Deploy the system in cloud environments,
- Simulate high volumes of concurrent users,

- Evaluate system performance under stress conditions.

This would determine enterprise-level feasibility.

**4. Cost and Sustainability Analysis**

Further research could examine:

- Implementation costs,
- Maintenance requirements,
- Organizational impact,
- Long-term sustainability.

Understanding these factors is essential for real-world adoption.

**5. Comparison of Different Zero Trust Frameworks**

Future studies could compare:

- Zero Trust Network Access (ZTNA),
- Micro-segmentation approaches,
- Hybrid Zero Trust architectures across industries.

This would provide deeper strategic insight into model selection.

## 11. Analyze results in recommended actions for improvements and future research considerations(M4)

### 11.1. Analytical overview of results

**1. Security Effectiveness Analysis**

The implementation of the "Never Trust, Always Verify" principle successfully eliminated implicit trust within the internal system architecture.

In the developed system:

- All requests from the React frontend must pass through JWT authentication middleware in the Node.js/Express backend.
- The system verifies:
    - Token validity

  - User role
  - Account status (active or locked)
- Role-Based Access Control (RBAC) ensures strict authorization enforcement.

Achieved Security Improvements:

- Prevention of unauthorized internal API access
- Reduction of privilege misuse and privilege escalation risks
- Restriction of access strictly to job-related resources
- Full activity logging (login attempts, document access, data modifications)

Compared to traditional perimeter-based security models that mainly protect the network boundary, this Zero Trust implementation secures the system at the application layer, which significantly strengthens internal protection.

Additionally:

- MongoDB stores detailed activity logs for auditing purposes.
- The React-based monitoring dashboard enables administrators to observe user behavior in near real time.

This confirms that the system enhances both preventive security and early detection capabilities.

**2. Technical Impact Analysis**

Although security was significantly strengthened, several technical impacts were identified during implementation.

**a. Increased System Complexity**

The integration of:

- JWT-based authentication
- Role-checking middleware
- Protected routes on both frontend (React) and backend (Express)
- Detailed logging mechanisms

Resulted in a multi-layered architecture rather than a basic CRUD system.

The system now consists of:

- Presentation Layer (React + TailwindCSS + TypeScript)
- API Layer (Express)
- Authentication Layer
- Authorization Layer
- Monitoring Layer
- Database Layer (MongoDB)

This architecture requires structured code organization and careful management, especially when using TypeScript for type safety and scalability.

**b. Performance Overhead**

Since every request requires:

- Token verification
- Role validation
- Logging activity

A slight increase in response time was observed compared to systems without strict access validation.

In a small-scale testing environment, performance remained stable. However, for large-scale enterprise deployment, further optimization would be required, such as:

- MongoDB indexing optimization
- Caching mechanisms (e.g., Redis)
- Load balancing strategies
- Log management optimization

These findings indicate that Zero Trust implementation requires adequate infrastructure planning to maintain scalability and high availability.

**c. Increased Storage and Processing Requirements**

Continuous logging significantly increases:

- Database storage consumption

- Query workload
- Overall system resource usage

While this improves traceability and accountability, future implementations may require:

- Log rotation policies
- Log archiving strategies
- Separate monitoring databases

**3. Organizational and Management Considerations**

The results highlight that Zero Trust is not solely a technical challenge but also an organizational transformation.

In this system:

- Access policies must be clearly defined and regularly updated.
- Role changes must be promptly reflected in the database.
- Accounts must be revoked immediately when employees leave the organization.

Without structured governance and identity lifecycle management, even a technically secure system may face operational risks.

Furthermore, employees must understand the purpose of additional verification steps. Without proper awareness training, stricter security measures may negatively affect morale and user acceptance.

Therefore, successful Zero Trust implementation requires coordination between technical teams and management.

## 11.2. Recommendations for improving future research

**1. Implementation of Risk-Based and Adaptive Authentication**

Future research could extend beyond static RBAC to include:

- IP anomaly detection
- Abnormal login time detection
- Device fingerprinting
- Behavioral pattern analysis

This would transform the system from basic Zero Trust into Adaptive Zero Trust Architecture.

**2. Integration of Artificial Intelligence for Anomaly Detection**

Since the system collects large volumes of log data in MongoDB, future work could incorporate machine learning techniques to:

- Detect suspicious login patterns
- Identify unusual access behaviors
- Predict potential insider threats

This would significantly enhance proactive security capabilities.

**3. Scalability Testing and Infrastructure Optimization**

Future research should evaluate the system under high concurrent user loads (e.g., 1000+ users). Potential improvements include:

- Microservices architecture (separate authentication service)
- Redis caching integration
- Containerization using Docker
- Deployment with Kubernetes for scalability

**4. Usability and Human Factors Evaluation**

Since stricter security measures may affect productivity, future research should analyze:

- User satisfaction levels
- Productivity before and after Zero Trust implementation
- Authentication fatigue

Combining cybersecurity research with human-computer interaction (HCI) studies would provide a more balanced evaluation.

## 11.3. Practical applications and future integration

**1. Enterprise-Level Application**

The developed Zero Trust monitoring system can be applied in:

- Technology companies

- Educational institutions
- Organizations handling sensitive internal documents
- Enterprises operating remote or hybrid working models

Implementation can follow a phased approach:

1. Deploy JWT authentication and RBAC
2. Add multi-factor authentication (MFA)
3. Enable comprehensive logging
4. Deploy monitoring dashboards

**2. Integration with Existing Systems**

The system can be integrated with:

- Google OAuth authentication
- LDAP or Active Directory
- Cloud platforms (AWS, Azure)
- API Gateway solutions

This makes it adaptable to modern hybrid infrastructures

**3. Zero Trust as a Service (ZTaaS)**

Instead of building in-house systems, organizations may adopt Zero Trust as a Service from specialized providers. This ensures professional management, continuous updates, and scalability while reducing internal development complexity.

**4. Long-Term Technological Integration**

Future integration could include:

- AI-driven threat detection
- Automated incident response systems
- SIEM platform integration
- Real-time anomaly detection dashboards

Such advancements would enhance proactive defense against increasingly sophisticated cyber threats

## 12. Demonstrate reflection and engagement in the resource process leading to recommended actions for future improvement (D3)

### 12.1. Reflection on Project Planning and Resource Management

When I started developing the internal company monitoring website based on the Zero Trust model, I initially focused more on building functional features such as login, role management, and dashboards. However, during the development process, I gradually realized that implementing Zero Trust was far more complex than I had expected.

At the beginning, I underestimated the amount of time needed to properly design the authentication and authorization mechanisms. Implementing JWT authentication, role-based middleware in Express, protected routes in React, and detailed activity logging required careful planning and restructuring multiple times. I learned that security-focused systems cannot be treated like normal CRUD applications. Instead of coding features first, I should have designed the security architecture more thoroughly before starting implementation.

In terms of technical resources, using React with TypeScript improved code safety and maintainability, but it also increased development difficulty because I had to manage strict types across components and API responses. On the backend, Node.js and Express were flexible, but organizing middleware for authentication and RBAC required clear structure to avoid messy code. MongoDB was easy to use, but I noticed that continuous logging quickly increased data volume, which made me realize the importance of database indexing and storage planning.

Overall, this project taught me that building a Zero Trust system requires not only technical skills but also careful planning, time management, and architectural thinking

### 12.2. Strategic sampling, data selection, and reflective lessons

For the research part, I conducted a survey with 13 participants, mainly people with IT knowledge. While this helped me collect relevant opinions about Zero Trust awareness and security attitudes, I recognize that the sample size was small and not fully representative of a real company environment.

Most participants had technical backgrounds, so their understanding of cybersecurity concepts was relatively high. In reality, many employees in organizations may not have strong IT knowledge. If I had included participants from non-technical backgrounds, the results about usability concerns and resistance to stricter security might have been different.

Another limitation is that the research mainly focused on perception-based data from survey responses. Although this helped me understand attitudes toward continuous authentication and RBAC, I did not collect enough real performance metrics such as response time, system load under high traffic, or detailed usability testing data. In future research, combining survey data with system performance evaluation would provide stronger and more balanced conclusions.

Through this process, I realized that research should not only confirm assumptions but also challenge them by collecting diverse and measurable evidence.

### 12.3. Recommended actions for future improvements

Based on my reflection, several improvements can be made in the future.

First, I would start with a more detailed security architecture design before development. This includes threat modeling, defining access control matrices, and planning identity lifecycle management (account creation, role updates, and account deactivation). This would reduce the need for restructuring later.

Second, I would expand the research scope by increasing the number of participants and including employees from different departments. I would also conduct usability testing to evaluate how stricter authentication affects productivity and user experience.

Third, from a technical perspective, the system could be improved by implementing adaptive security mechanisms, such as anomaly detection based on user behavior. Since the system already stores activity logs in MongoDB, this data could be analyzed using machine learning techniques in the future.

Fourth, scalability testing should be performed. The current system works well in a small testing environment, but enterprise-level deployment would require load testing, caching mechanisms, and possibly a microservices architecture.

Finally, I realized that Zero Trust is not only about technology. It also requires clear organizational policies and user awareness. Future improvements should include security training for users and structured governance processes to ensure that access rights are updated properly when employees change roles or leave the organization.

## III Conclusion

This project aimed to design and develop an internal company monitoring website based on the Zero Trust security model. Through the combination of React, TypeScript, TailwindCSS on the frontend and Node.js, Express, and MongoDB on the backend, the system was successfully implemented to enforce strict authentication, role-based access control, and continuous activity monitoring.

The results demonstrate that applying the “Never Trust, Always Verify” principle significantly strengthens internal security. By ensuring that every request is authenticated and authorized, the system reduces the risks of unauthorized access, privilege misuse, and internal threats. Compared to traditional perimeter-based security models, this approach provides stronger protection at the application level, which is more suitable for modern distributed and hybrid working environments.

In addition to improving security, the project also revealed important technical and organizational considerations. Implementing Zero Trust increased system complexity and required careful management of authentication flows, access control policies, and logging mechanisms. Furthermore, it highlighted that cybersecurity is not only a technical issue but also a matter of governance, user awareness, and policy enforcement.

The research component, including surveys and expert interviews, supported the practical implementation by showing that most participants recognize the importance of continuous verification and role-based access control. However, the findings also indicate that stricter security measures may affect user convenience, reinforcing the need to balance security and usability.

Overall, this project confirms that Zero Trust architecture is both feasible and beneficial when applied to internal company systems. While further improvements such as scalability testing, AI-based anomaly detection, and enhanced usability evaluation are recommended, the developed system provides a strong foundation for secure internal monitoring aligned with modern cybersecurity standards.

This experience has strengthened my understanding of secure system architecture and demonstrated the importance of integrating technical design, research analysis, and organizational awareness in building effective cybersecurity solutions.

## IV Reference